



Microsoft Cybersecurity Reference Architectures (MCRA)

Plan your end-to-end security
architecture using Zero Trust principles

Top End to End Security Challenges

- Incomplete or network-centric architectures aren't agile & can't keep up with continuous change (security threats, technology platform, and business requirements)
- Challenges with
 - Creating integrated end to end architecture
 - Integrating security technologies
 - Planning and prioritizing security modernization initiatives

MCRA is a subset of the full Security Architecture Design Session (ADS) module 1 workshop:



SAF Overview

MCRA Agenda

- Overview of Security Adoption Framework and end to end cybersecurity architecture
 - **End to End Security:** Consider the whole problem
 - **Ruthlessly Prioritize:** Identify top gaps + quick wins
 - **Get started:** Start somewhere & continuously improve
- Antipatterns and best practices
- Guiding rules and laws for security
- Diagrams and references
Applying Zero Trust principles





Whiteboard – Current Security Architecture

Business and Technical Drivers

- What is top of mind for business stakeholders?
- What risks are important to the business?
- Business/technology initiatives driving change?
- What metrics are important to your program?



Geography and Cloud Usage

- Where does your organization operate?
- Which workloads are in the cloud? Which major cloud providers? (SaaS, PaaS, IaaS)

Architecture, Policy, and Collaboration

Describe how teams work together on end to end security + guiding documents/artifacts

- Enterprise-wide security architecture approach and documentation
- Policy update, monitoring, and related governance processes
- Posture and vulnerability management processes
- Technical collaboration processes (e.g. sharing learnings, joint technical planning, etc. with security operations, architects, engineers, posture management, governance, others)
- Differences between on premises vs. cloud processes



Compliance

Large & notable regulatory requirements



Threats

What types of attacks and adversaries are top of mind?



Security Adoption Framework (SAF)

Zero Trust security modernization aligned to business goals and risks

End to End Reference Strategy, Architecture, & Implementation using Zero Trust principles



Business Scenarios
Promised Outcomes

- I want to rapidly and securely adopt AI (including protecting data)
- I want people to do their job securely from anywhere
- I want to minimize business damage from security incidents
- I want to identify and protect critical business assets
- I want to continuously improve my security posture and compliance



Security Disciplines - Reference architectures, plans, and more

- ➔ Strategy, Integration, and Governance
- ➔ Access and Identity
- ➔ Security Operations (SecOps/SOC)
- ➔ Infrastructure & Development Security
- ➔ Data Security
- ➔ OT and IoT Security

Artificial Intelligence (AI)



Technology Implementation

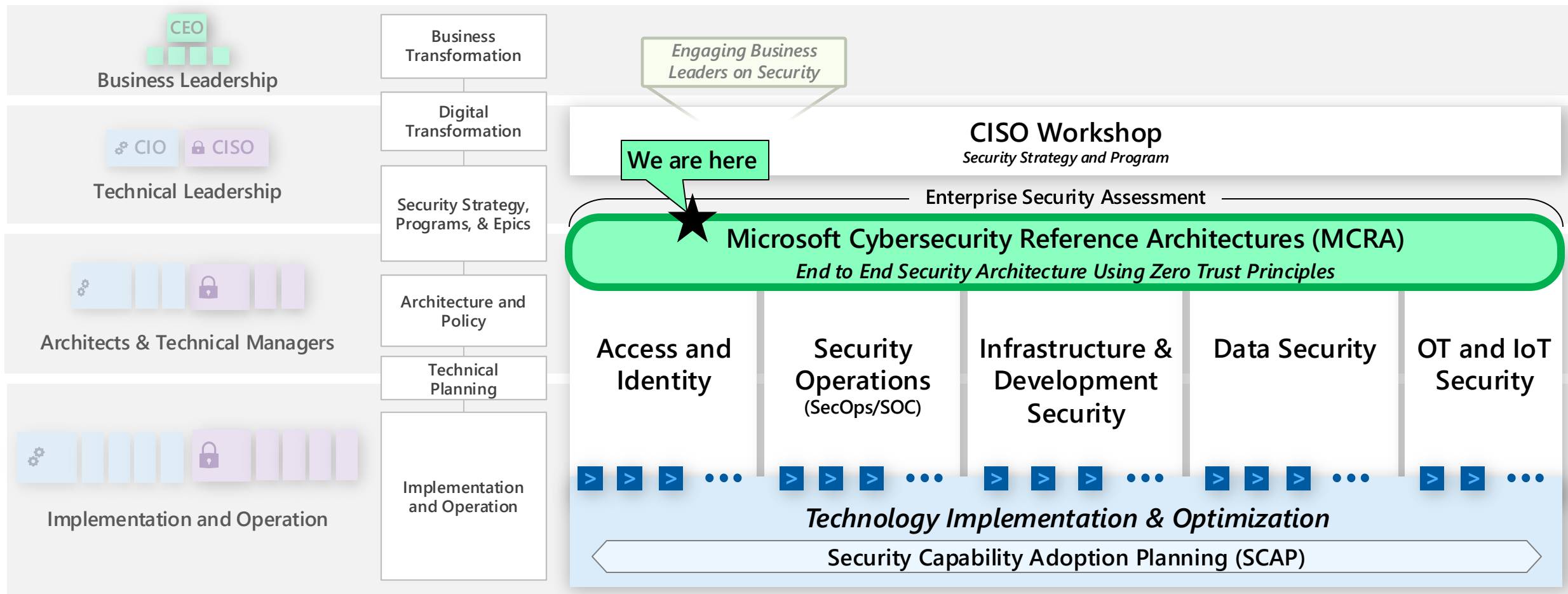
- ➔ Endpoints
- ➔ Identities
- ➔ Network
- ➔ Apps
- ➔ AI
- ➔ Data
- ➔ Infrastructure



Security Adoption Framework (SAF)



Zero Trust security modernization rapidly reduces organizational risk



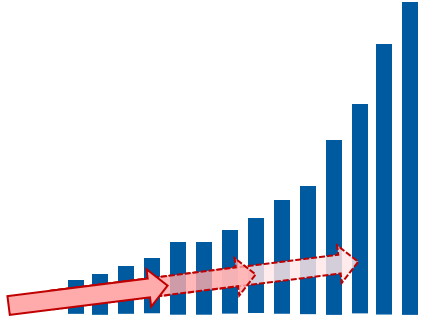
*Includes
Reference Plans*

Workshops available in Microsoft Unified

Coordinated & integrated end-to-end security across the 'hybrid of everything' (on-prem, multi-cloud, IoT, OT, etc.)

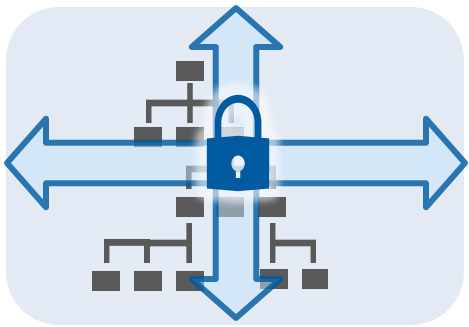
Security must be integrated everywhere

and stay on a journey of continuous improvement



Attackers prefer cheapest and easiest options

...but are often willing to go further and spend more



Security impacting decisions are made by most roles

- **Everybody** has security accountabilities and/or responsibilities
- **Decision Makers** are accountable for security outcomes of their decisions
- **Security teams** must enable and support all roles across the organization (including business, engineering, and more)

Continuous improvement, learning, and prioritization are critical to manage this

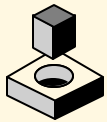
Common Security Antipatterns - Technical Architecture

Common mistakes that impede security effectiveness and increase organizational risk



Skipping basic maintenance

Skipping backups, disaster recovery exercises, and software updates/patching on assets



Securing cloud like on premises

Attempting to force on-prem controls and practices directly onto cloud resources



Wasting resources on legacy

Legacy system maintenance and costs draining ability to effectively secure business assets



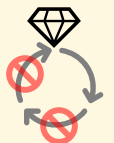
Artisan Security

Focused on custom manual solutions instead of automation and off the shelf tooling



Disconnected security approach

Independent security teams, strategies, tech, and processes for network, identity, devices, etc.



Lack of commitment to lifecycle

Treating security controls and processes as points in time instead of an ongoing lifecycle

Best Practices

Develop and implement an **end to end technical security strategy** focused on durable capabilities and Zero Trust Principles

This workshop helps you define and rapidly improve on best practices across security including:

- ***Asset-centric security*** aligned to business priorities & technical estate (beyond network perimeter)
- ***Consistent principle-driven approach*** throughout security lifecycle
- ***Pragmatic prioritization*** based on attacker motivations, behavior, and return on investment
- ***Balance investments*** between innovation and rigorous application of security maintenance/hygiene
- ***'Configure before customize'*** approach that embraces automation, innovation, and continuous improvement
- ***Security is a team sport*** across security, technology, and business teams

Security Success

Invest intentionally into providing these durable outcomes



Attacker Failure + Increased Attacker Cost/Friction

Block Cheap and Easy Attacks

Increase cost and friction for well known & proven attack methods (or easy to block options)

Find and kick them out fast

Reduce dwell time (mean time to remediate) with rapid detection and remediation

'Left of Bang'



'Right of Bang'

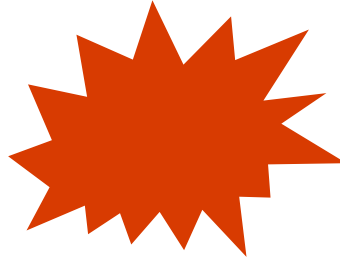
Requires end to end collaboration

Improving Resiliency

Enable business mission while continuously increasing security assurances

'Left of Bang'

Prevent or lessen impact of attacks



'Right of Bang'

Rapidly and effectively manage attacks



The job will never be 'done' or 'perfect', but it's important to keep doing (like cleaning a house)

[NIST Cybersecurity Framework v2](#)

End to End Security

Enable business mission and increasing security assurances with intentional approach

Security Strategy and Program

Zero Trust Architecture

Security Posture Management

Modern Security Operations (SecOps/SOC)

Access and Identity

Infrastructure & Development Security

IoT and OT Security

Data Security

'Left of Bang'

Prevent or lessen impact of attacks

'Right of Bang'

Rapidly and effectively manage attacks



IDENTIFY

PROTECT

DETECT

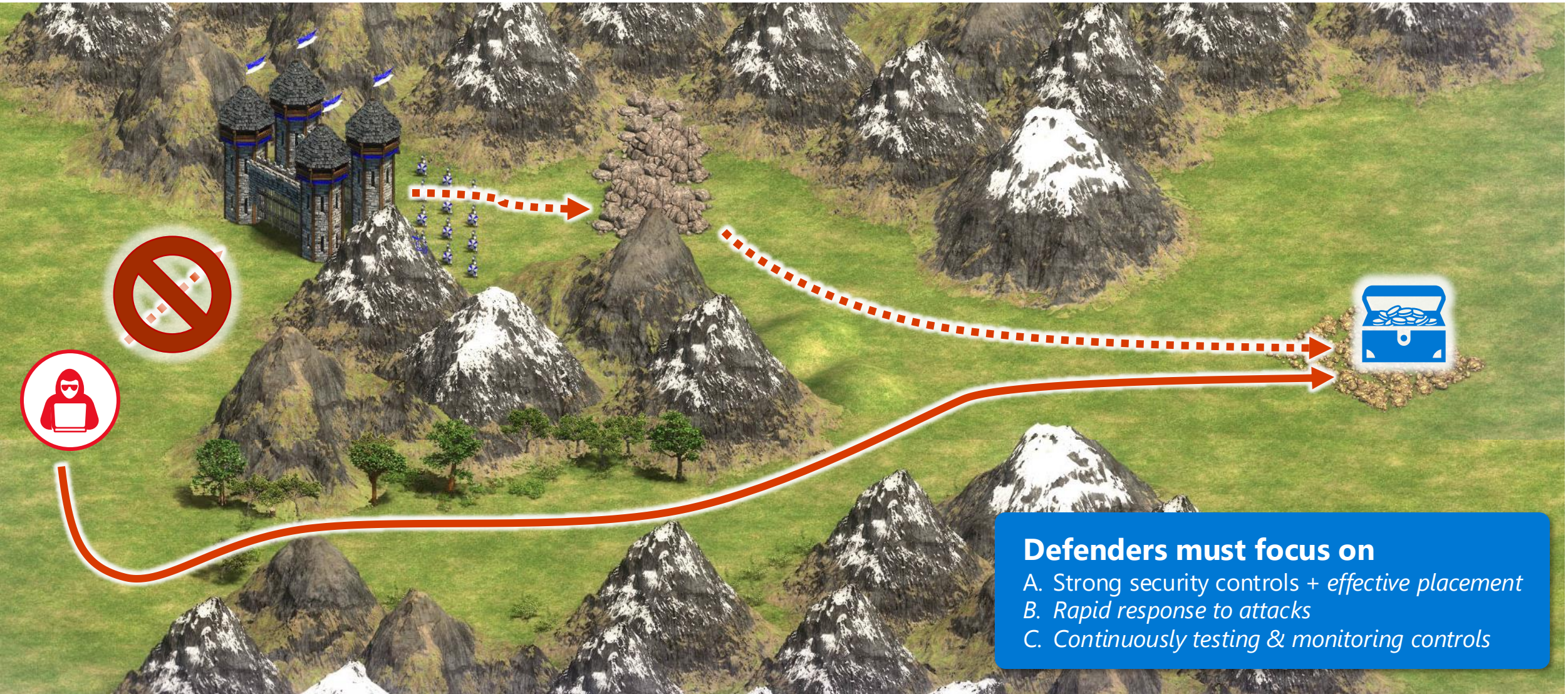
RESPOND

RECOVER

GOVERN

Attackers choose the path of least cost/resistance

Antipattern: Believing attackers will follow the planned path



Attackers use what they see, know, and can guess

High

Looks like they have NGFW, IDS/IPS, and DLP

Low

I bet their admins

1. Check email from admin workstations
2. Click on links for higher paying jobs

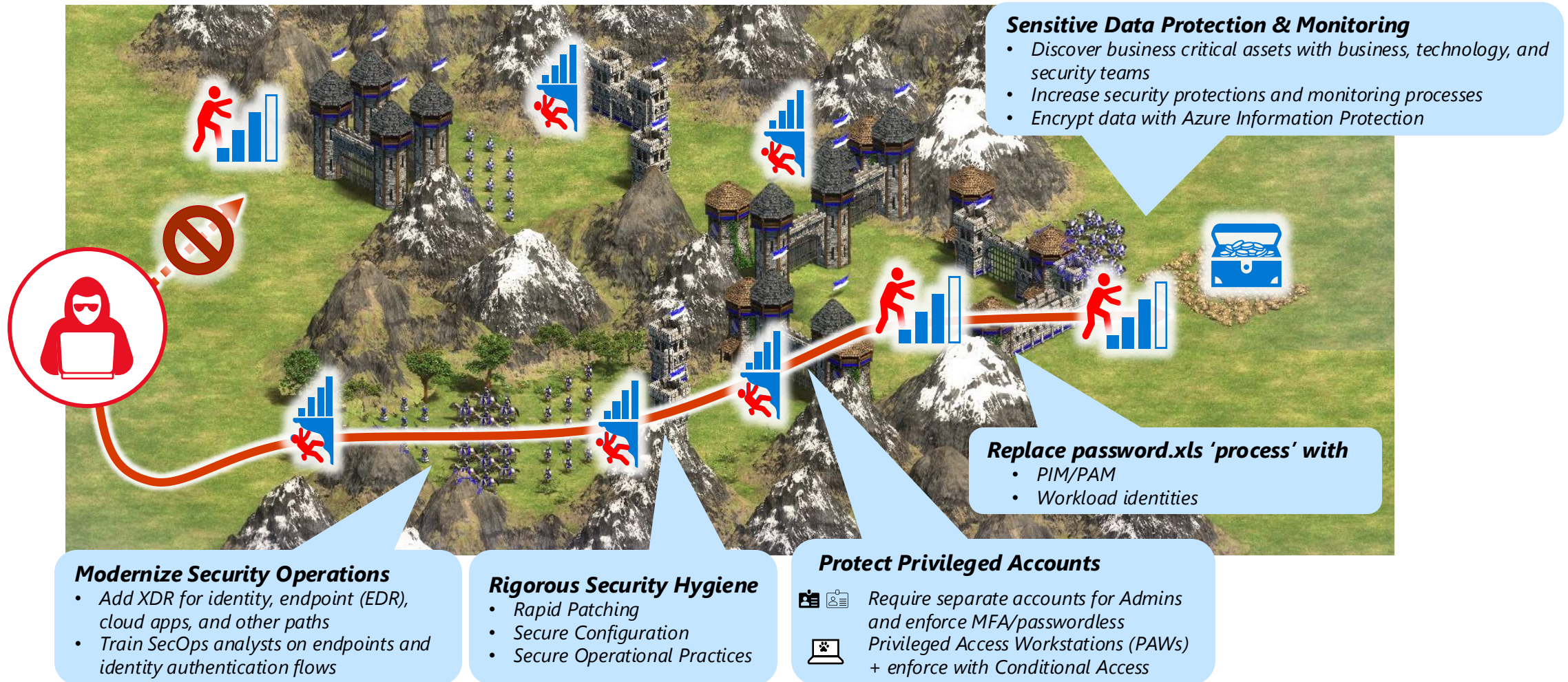
Phishing email to admin ✓

Found passwords.xls ✓

Now, let's see if admins save service account passwords in a spreadsheet...

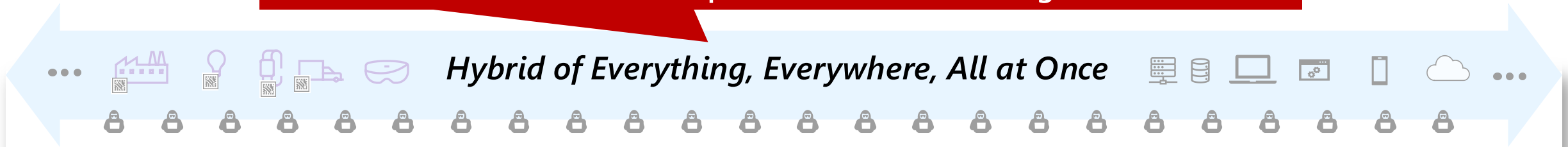
Strategically position security investments

Raise cost and friction on attacker's easiest and highest impact paths



Security is complex and challenging

Attacks can shut all business operations down, creating board level risk



Must secure across everything

- **Brand New** - IoT, DevOps, and Cloud services, devices and products
- **Current/Aging** - 5-25 year old enterprise IT servers, products, etc.
- **Legacy/Ancient** - 30+ year old Operational Technology (OT) systems

Nothing gets retired!

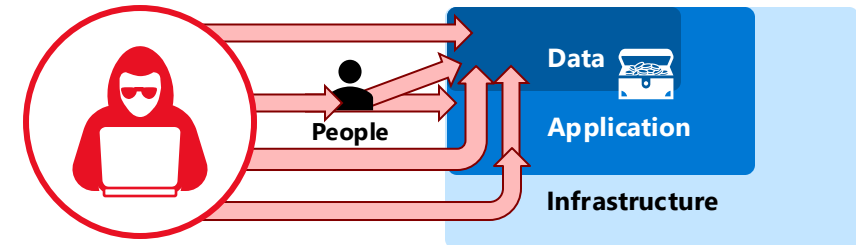
Usually for fear of breaking something (& getting blamed)

'Data swamp' accumulates
managed data + unmanaged 'dark' data



Attackers have a lot of options

- *Forcing security into a holistic complex approach*



- **Regulatory Sprawl** - 200+ daily updates from 750 regulatory bodies
- **Threats** – Continuously changing threat landscape
- **Security Tools** – dozens or hundreds of tools at customers



Goal: Zero Assumed Trust

Reduce risk by finding and removing implicit assumptions of trust

False Assumptions

of implicit or explicit trust

Security is the opposite of productivity

All attacks can be prevented

Network security perimeter will keep attackers out

Passwords are strong enough

IT Admins are safe

IT Infrastructure is safe

Developers always write secure code

The software and components we use are secure



With 30+ years of backlog at most organizations, it will take a while to burn down the backlog of assumed trust

Zero Trust Mitigation

Systematically Build & Measure Trust

Business Enablement

Align security to the organization's mission, priorities, risks, and processes

Assume Compromise

Continuously reduce blast radius and attack surface through prevention and detection/response/recovery

Shift to Asset-Centric Security Strategy

Revisit how to do access control, security operations, infrastructure and development security, and more

Explicitly Validate Account Security

Require MFA and analyze all user sessions with behavior analytics, threat intelligence, and more

Plan and Execute Privileged Access Strategy

Establish security of accounts, workstations, and other privileged entities (aka.ms/spa)

Validate Infrastructure Integrity

Explicitly validate trust of operating systems, applications, services accounts, and more

Integrate security into development process

Security education, issue detection and mitigation, response, and more

Supply chain security

Validate the integrity of software and hardware components from open source, vendors, and others



Zero Trust Security Architecture

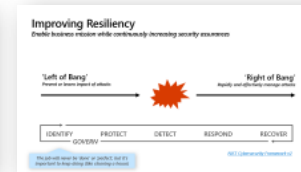
End to End Prioritized Execution + Continuous Improvement

1. Look End to End: *Consider the whole security problem*

OBSERVE, ORIENT



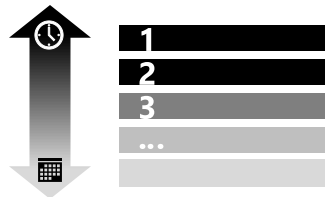
Security is complex and challenging



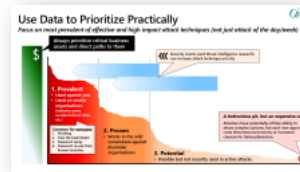
Resilience required across the lifecycle

2. Ruthlessly Prioritize: *Identify top gaps + quick wins*

DECIDE



Focus on prevalent attacks and use data



Disrupt attacker return on investment (ROI)

3. Get started: *Start somewhere and continuously improve*

ACT



Microsoft Security Adoption Framework



Leverage reference plans and architectures

Guiding Rulesets for End to End Architecture

Zero Trust Commandments
Standardized Rules for Zero Trust security

Assume Success  Assume Failure

Practice Deliberate Security
Establishes pragmatic view of 'trust' in today's world of continuous threats + how to prioritize applying that in a world of complex and continuously changing requirements

- Secure Assets by Organizational Risk
- Validate Trust Explicitly

Develop a Security-Centric Culture
Guides the application of security across all teams

- Practice Accountability
- Enable Pervasive Security
- Utilize Least Privilege
- Deploy Simple (User-Friendly) Security

Support Business Objectives
Aligns security explicitly to business priorities and assets (vs. networks) and considers long term implications

- Enable the Organization's Mission
- Implement Asset-Centric Controls
- Enable Sustainable Security

Deploy Agile and Adaptive Security
Ensures security can keep up with continuous change

- Make Informed Decisions
- Improve and Evolve Security Controls
- Utilize Defense in Depth
- Enable Resiliency

From publications.opengroup.org/c247

Zero Trust Commandments

Requirements that represent best practices for a Zero Trust Architecture (ZTA) and transformation. (The Open Group Standard)

Usage: General planning + Testing whether something is 'Zero Trust' or not

10 Laws of Cybersecurity Risk

aka.ms/SecurityLaws

- 1 Security success is ruining the attacker ROI (return on investment)
- 2 Not keeping up is falling behind
- 3 Productivity always wins
- 4 Attackers don't care
- 5 Ruthless Prioritization is a survival skill
- 6 Cybersecurity is a team sport
- 7 Your network isn't as trustworthy as you think it is
- 8 Isolated networks aren't automatically secure
- 9 Encryption alone isn't a data protection solution
- 10 Technology doesn't solve people & process problems

10 Laws of Cybersecurity Risk

Key truths about managing security risk that bust common myths.

Usage: Ensuring security strategy, controls, and risk are managed with realistic understanding of how attacks, humans, and technology work

Immutable Laws of Security

aka.ms/SecurityLaws

- 1 If a bad actor can persuade you to run their program on your computer, it's not solely your computer anymore.
- 2 If a bad actor can alter the operating system on your computer, it's not your computer anymore.
- 3 If a bad actor has unrestricted physical access to your computer, it's not your computer anymore.
- 4 If you allow a bad actor to run active content in your website, it's not your website anymore.
- 5 Weak passwords trump strong security.
- 6 A computer is only as secure as the administrator is trustworthy.
- 7 Encrypted data is only as secure as its decryption key.
- 8 An out-of-date anti-malware scanner is only marginally better than no scanner at all.
- 9 Absolute anonymity isn't practically achievable, online or offline.
- 10 Technology isn't a panacea.

Immutable Laws of Security

Key truths about security claims and controls that bust common myths.

Usage: Validating design of security controls, systems, and processes to ensure they are technically sound

Microsoft Cybersecurity Reference Architectures (MCRA)

Architecture Diagrams & References



Security Adoption Framework (SAF)

Threat Environment

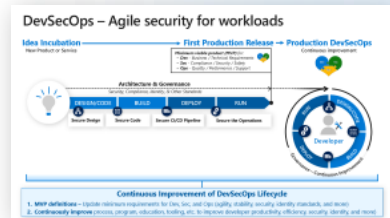
Ransomware/Extortion, Data Theft, and more



Attack Chain Coverage

Development / DevSecOps

Enabling Security & Business Goals



Infrastructure

Multi-cloud, cross-platform, native controls



Patch Modernization



Microsoft 365 E5

People

Roles and Risk Management



Role Mapping



Artificial Intelligence (AI) and Security

Zero Trust



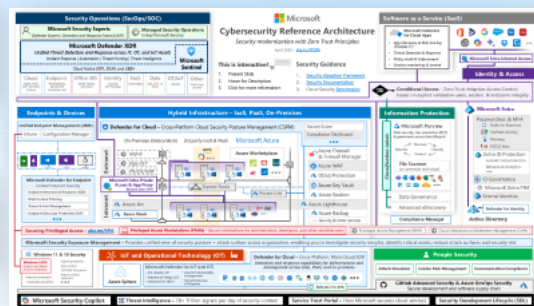
Microsoft Security Capabilities



Multi-Cloud & Cross-Platform



Microsoft 365 E5



Build Slide



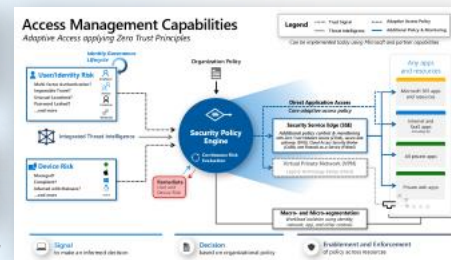
Standards Mapping

Zero Trust Adaptive Access

Security Service Edge (SSE)



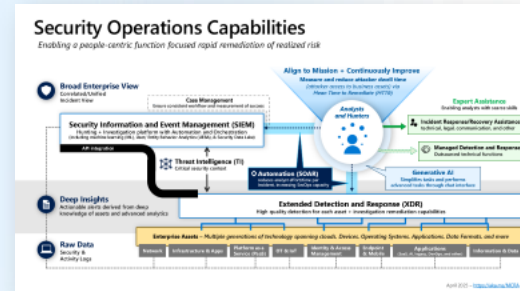
Journey



Privileged Access

Security Operations

(SecOps/SOC)

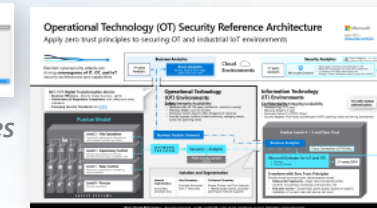


Operational Technology (OT)

Industrial Control Systems



Device Types

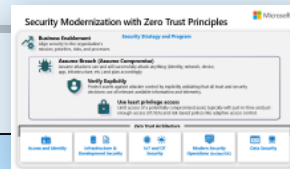


Security Adoption Framework

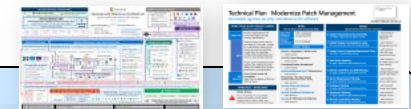
Reduce risk by rapidly modernizing security capabilities and practices



Security Strategy and Program *CISO Workshop*



Zero Trust Architecture



Microsoft Cybersecurity Reference Architectures (MCRA)

Access and Identity



Modern Security Operations (SecOps/SOC)



Infrastructure & Development Security



*Includes
Reference Plans*

Workshops available in the Microsoft Unified catalog

All are holistic for the 'hybrid of everything' technical estate (on-premises, multi-cloud, IoT, OT, etc.)

Where do you want to go next?

Engagements help navigate the vast complexity of security

- Recommend combination of:
- Context – Strategy/Architecture
 - Action – Technical Implementation

What do we own? Are we using it?

Capabilities Review

Security Capability Adoption Planning (SCAP)

How are we doing today?

End to End Security Assessment

Enterprise Security Assessment (ESA)

Strategic Security Integration

Security Strategy
and Program



End to End Security Architecture
Microsoft Cybersecurity Reference Architectures (MCRA)

Technical Architecture and Planning

Access and
Identity

Modern
Security
Operations
(SecOps/SOC)

Infrastructure &
Development
Security

Data Security

Microsoft Product and Technology Implementation



Defender



Purview



Entra



Sentinel



Security Copilot



Intune



Security
Modernization
Journey

Let's get next steps locked in

Capture actions and who follows up on them

#	Next Step	Point of Contact
1		
2		
3		
4		
5		

Security Resources



Security Adoption Framework

aka.ms/saf

Security Hub
aka.ms/SecurityDocs

Security Strategy and Program

- CISO Workshop – aka.ms/CISOworkshop | [-videos](#)

- Driving Business Outcomes Using Zero Trust
 - [Rapidly modernize your security posture for Zero Trust](#)
 - [Secure remote and hybrid work with Zero Trust](#)
 - [Identify and protect sensitive business data with Zero Trust](#)
 - [Meet regulatory and compliance requirements with Zero Trust](#)

End to End Security Architecture

- Microsoft Cybersecurity Reference Architectures (MCRA) - aka.ms/MCRA | [-videos](#)
- Ransomware and Extortion Mitigation - aka.ms/humanoperated
- Backup and restore plan to protect against ransomware - aka.ms/backup

- Zero Trust Workshop - <http://aka.ms/ztworkshop>
- Zero Trust Deployment Guidance - aka.ms/ztguide | aka.ms/ztramp

Secure Access and Identities

- Securing Privileged Access (SPA) Guidance
aka.ms/SPA
- [Access Control Discipline](#)
- Ninja Training
 - Microsoft Defender for Identity
aka.ms/mdininja
- MCRA Video
 - [Zero Trust User Access](#)
- Microsoft Entra Documentation
aka.ms/entrados

Modern Security Operations (SecOps/SOC)

- Incident Response - aka.ms/IR
- CDOC Case Study - aka.ms/ITSOC
- Ninja Training
 - Microsoft 365 Defender
aka.ms/m365dninja
 - Microsoft Sentinel
aka.ms/sentinelninja
 - Microsoft Defender for Office 365
aka.ms/mdoninja
 - Microsoft Defender for Endpoint
aka.ms/mdeninja
 - Microsoft Cloud App Security
aka.ms/mcasninja
- MCRA Videos
 - [Security Operations](#)
 - [SecOps Integration](#)

Infrastructure & Development Security

- [Security Development Lifecycle \(SDL\)](#)
 - [Security Controls](#)
- Microsoft Cloud Security Benchmark
aka.ms/benchmarkdocs
- Well Architected Framework (WAF)
 - aka.ms/wafsecure
- Azure Security Top 10
 - aka.ms/azuresecuritytop10
- Ninja Training
 - [Defender for Cloud](#)
- MCRA Video
 - [Infrastructure Security](#)
- [Defender for Cloud Documentation](#)

Data Security

- [Secure data with Zero Trust](#)
- Ninja Training
 - Microsoft Purview Information Protection
aka.ms/MIPNinja
 - Microsoft Purview Data Loss Prevention
aka.ms/DLPNinja
 - Microsoft Purview Insider Risk Management
 - [Insider Risk Management](#)
 - Data Security for SOC
aka.ms/NinjaDSforSOC
- Microsoft Purview Documentation
aka.ms/purviewdocs

IoT and OT Security

- Ninja Training
 - [Defender for IoT Training](#)
- MCRA Videos
 - [MCRA Video OT & IIoT Security](#)
- Defender for IoT Documentation
aka.ms/D4IoTDocs

Key Industry References and Resources



The Open Group

- Zero Trust Commandments Standard - <https://publications.opengroup.org/c247>
- Zero Trust Reference Model - <https://publications.opengroup.org/s232>
- Security Principles for Architecture - <https://publications.opengroup.org/c246>



US National Institute of Standards and Technology (NIST)

- Cybersecurity Framework - <https://www.nist.gov/cyberframework>
- Zero Trust Architecture - <https://www.nist.gov/publications/zero-trust-architecture>
 - NCCoE Zero Trust Project - <https://www.nccoe.nist.gov/projects/implementing-zero-trust-architecture>
- Secure Software Development Framework (SSDF) - <https://csrc.nist.gov/pubs/sp/800/218/final>

CYBERSECURITY &
INFRASTRUCTURE
SECURITY AGENCY



Cybersecurity and Infrastructure Security Agency (CISA)

- Zero Trust Maturity Model - <https://www.cisa.gov/zero-trust-maturity-model>



Center for Internet Security (CIS)

- CIS Benchmarks - <https://www.cisecurity.org/cis-benchmarks/>

Standards Mapping

References

Key Industry References and Resources

The Open Group

- Zero Trust Conceptual Model - <https://pubs.opengroup.org/standards/zero-trust-conceptual-model/>
- Zero Trust Reference Model - <https://pubs.opengroup.org/standards/zero-trust-reference-model/>
- Security Principles for Architecture - <https://pubs.opengroup.org/standards/zero-trust-security-principles-for-architecture/>

NIST

- US National Institute of Standards and Technology (NIST)
- Cybersecurity Framework - <https://www.nist.gov/publications/nist-cybersecurity-framework>
- Zero Trust Architecture - <https://www.nist.gov/publications/nist-zero-trust-architecture>
- Secure Software Development Framework (SSDF) - <https://www.nist.gov/publications/nist-secure-software-development-framework>

Cybersecurity and Infrastructure Security Agency (CISA)

- Zero Trust Maturity Model - <https://www.cisa.gov/zero-trust-maturity-model>

Center for Internet Security (CIS)

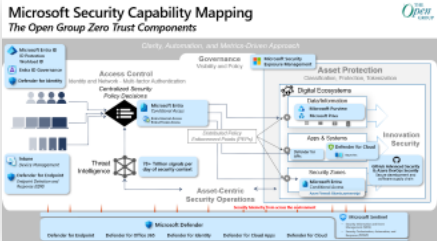
- CIS Benchmarks - <https://www.cisecurity.org/benchmarks>

Zero Trust Model The Open Group

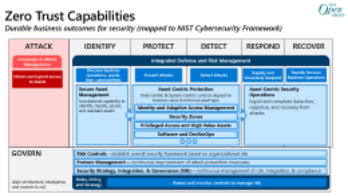
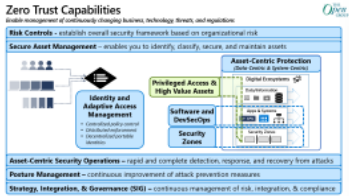
Key SecOps Terminology

SecOps

- Security Operations
- Operational Security
- Operational Resilience
- Operational Continuity
- Operational Readiness
- Operational Performance
- Operational Efficiency
- Operational Effectiveness
- Operational Reliability
- Operational Availability
- Operational Sustainability
- Operational Scalability
- Operational Flexibility
- Operational Adaptability
- Operational Resilience
- Operational Continuity
- Operational Readiness
- Operational Performance
- Operational Efficiency
- Operational Effectiveness
- Operational Reliability
- Operational Availability
- Operational Sustainability
- Operational Scalability
- Operational Flexibility
- Operational Adaptability

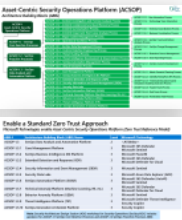


Zero Trust Capabilities The Open Group



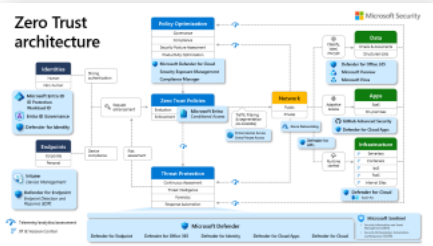
All capabilities ...mapped to NIST CSF

Asset-Centric Security Operations (SecOps/SOC)

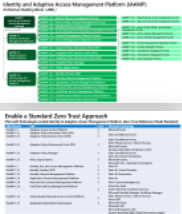
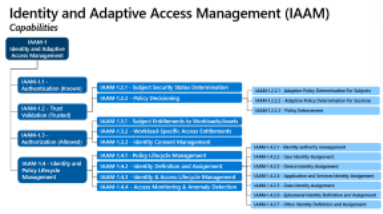


Architecture Building Blocks (ABBs)
Microsoft Mapping

Zero Trust Model Microsoft

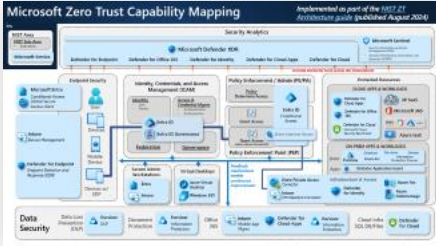


Identity and Adaptive Access Management (IAAM)



Architecture Building Blocks (ABBs)
Microsoft Mapping

Zero Trust Model NIST



Rapidly Report Regulatory Compliance



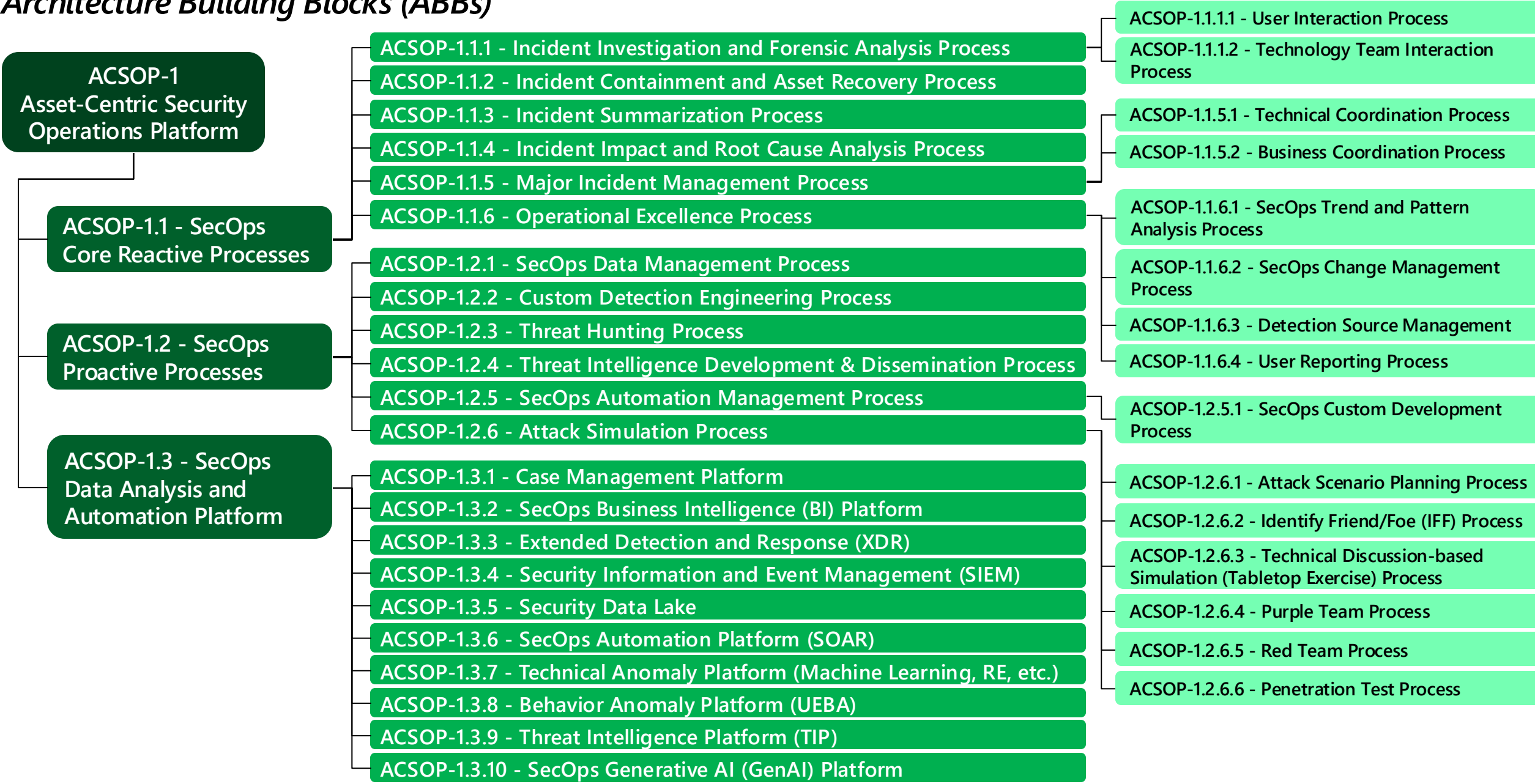
Asset-Centric Security Operations (ACSO)

Capabilities



Asset-Centric Security Operations Platform (ACSOP)

Architecture Building Blocks (ABBs)



Enable a Standard Zero Trust Approach

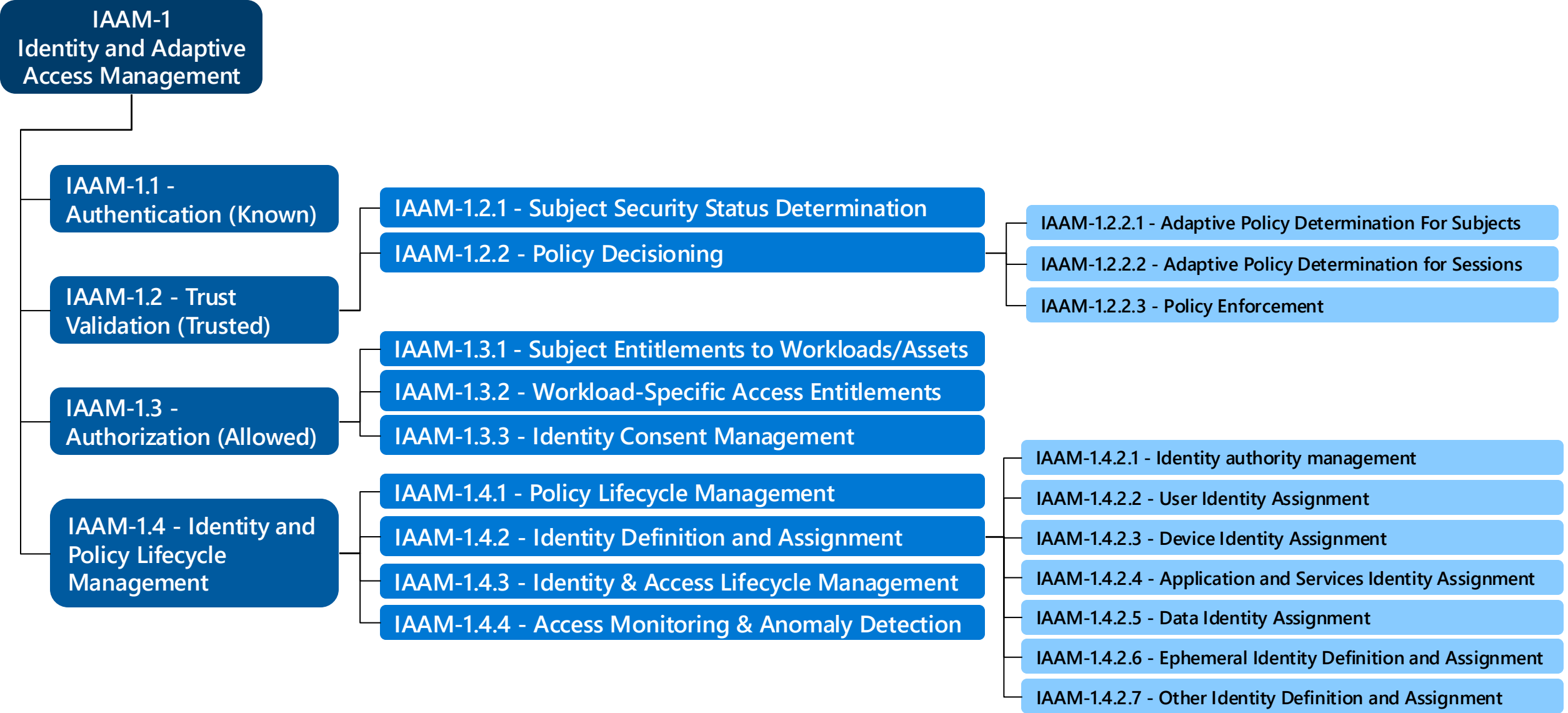
Microsoft Technologies enable Asset-Centric Security Operations Platform (Zero Trust Reference Model)

ABB #	Architecture Building Block (ABB) Name	Level	Microsoft Technology
ACSOP-1.3	SecOps Data Analysis and Automation Platform	2	<All Below>
ACSOP-1.3.1	Case Management Platform	3	Microsoft 365 Defender Microsoft Sentinel
ACSOP-1.3.2	SecOps Business Intelligence (BI) Platform	3	Microsoft PowerBI
ACSOP-1.3.3	Extended Detection and Response (XDR)	3	Microsoft 365 Defender Microsoft Defender for Cloud
ACSOP-1.3.4	Security Information and Event Management (SIEM)	3	Microsoft Sentinel
ACSOP-1.3.5	Security Data Lake	3	Microsoft Azure Data Explorer (ADX)
ACSOP-1.3.6	SecOps Automation Platform (SOAR)	3	Microsoft 365 Defender (AutoIR) Microsoft Sentinel
ACSOP-1.3.7	Technical Anomaly Platform (Machine Learning, RE, etc.)	3	Microsoft 365 Defender Microsoft Defender for Cloud
ACSOP-1.3.8	Behavior Anomaly Platform (UEBA)	3	Microsoft Sentinel
ACSOP-1.3.9	Threat Intelligence Platform (TIP)	3	Microsoft Defender Threat Intelligence Security Copilot
ACSOP-1.3.10	SecOps Generative AI (GenAI) Platform	3	Security Copilot

Note: Security Architecture Design Session (ADS) workshop for Security Operations (SecOps/SOC) includes guidance for *ACSOP-1.1 SecOps Core Reactive Processes* and *ACSOP-1.2 SecOps Proactive Processes ABBs*

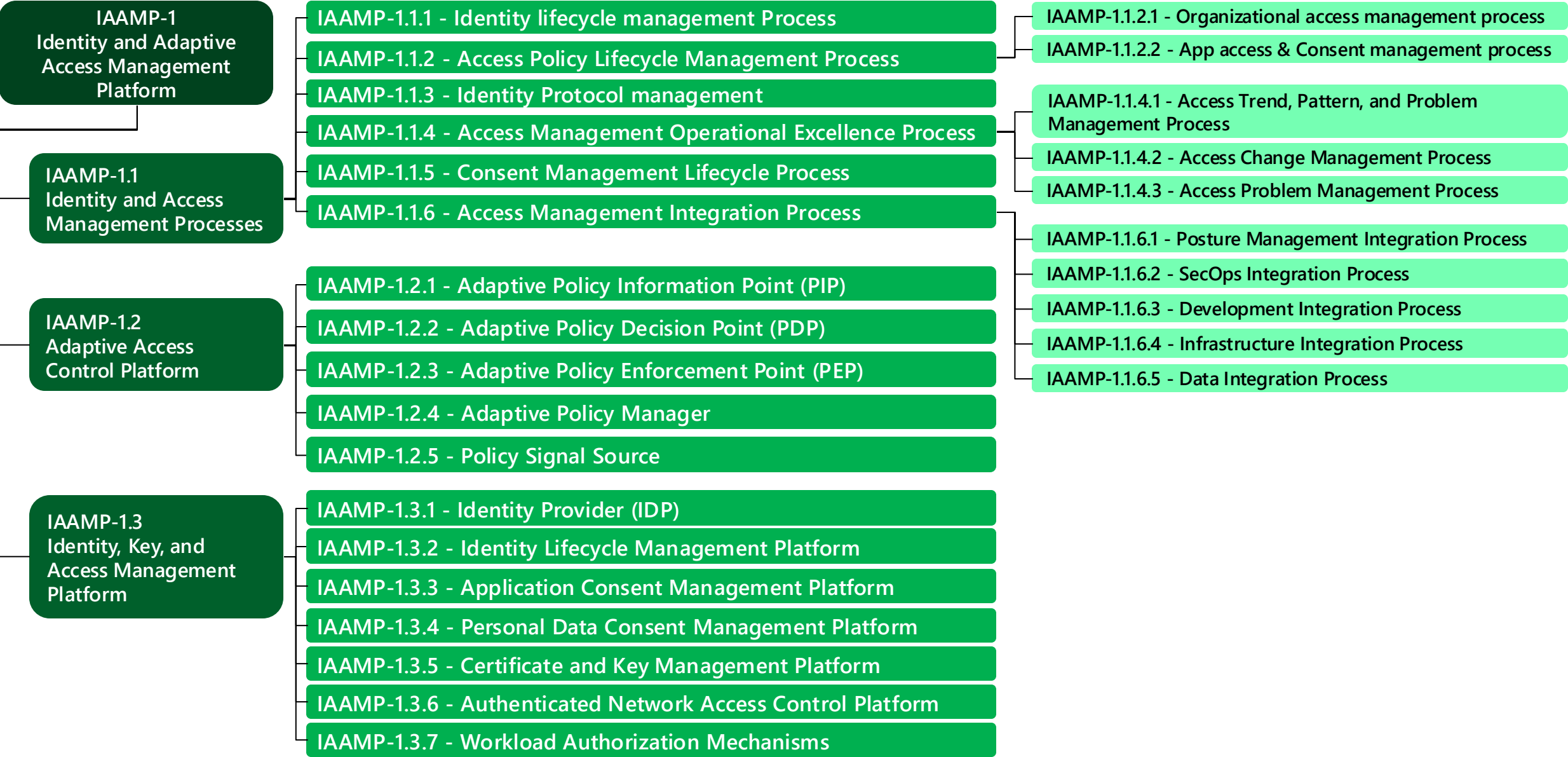
Identity and Adaptive Access Management (IAAM)

Capabilities



Identity and Adaptive Access Management Platform (IAAMP)

Architecture Building Blocks (ABBs)



Enable a Standard Zero Trust Approach

Microsoft Technologies enable Identity & Adaptive Access Management Platform (Zero Trust Reference Model Standard)

ABB Number	ABB	Level	Microsoft Technology
IAAMP-1.2	Adaptive Access Control Platform	2	Microsoft Entra
IAAMP-1.2.1	Adaptive Policy Information Point (PIP)	3	Entra Conditional Access
IAAMP-1.2.2	Adaptive Policy Decision Point (PDP)	3	
IAAMP-1.2.3	Adaptive Policy Enforcement Point (PEP)	3	Entra Conditional Access Entra Private Access / Internet Access Microsoft Intune Purview Information Protection & DLP
IAAMP-1.2.4	Adaptive Policy Manager	3	Entra Conditional Access
IAAMP-1.2.5	Policy Signal Source	3	Entra ID / Entra ID Protection Microsoft Intune Microsoft 365 – Defender for Endpoint
IAAMP-1.3	Identity, Key, and Access Management Platform	2	Entra ID
IAAMP-1.3.1	Identity Provider (IDP)	3	Entra ID, Active Directory
IAAMP-1.3.2	Identity Lifecycle Management Platform	3	Entra ID Governance
IAAMP-1.3.3	Application Consent Management Platform	3	Entra ID
IAAMP-1.3.4	Personal Data Consent Management Platform	3	Priva Consent Management
IAAMP-1.3.5	Certificate and Key Management Platform	3	Azure Key Vault Active Directory Certificate Services Microsoft Identity Manager Certificate Manager
IAAMP-1.3.6	Authenticated Network Access Control Platform	3	Entra Private Access / Internet Access Azure VPN
IAAMP-1.3.7	Workload Authorization Mechanisms	3	Microsoft Azure Microsoft 365 Microsoft Dynamics 365 <i>Custom Workload RBAC/ABAC/Permission models</i>

Security Modernization with Zero Trust Principles



Business Enablement

Align security to the organization's mission, priorities, risks, and processes

Security Strategy and Program



Assume Breach (Assume Compromise)

Assume attackers can and will successfully attack anything (identity, network, device, app, infrastructure, etc.) and plan accordingly



Verify Explicitly

Protect assets against attacker control by explicitly validating that all trust and security decisions use all relevant available information and telemetry.



Use least privilege access

Limit access of a potentially compromised asset, typically with just-in-time and just-enough-access (JIT/JEA) and risk-based policies like adaptive access control.

Zero Trust Architecture



Access and Identity



Infrastructure &
Development Security



IoT and OT
Security



Modern Security
Operations (SecOps/SOC)



Data Security

Zero Trust Principles

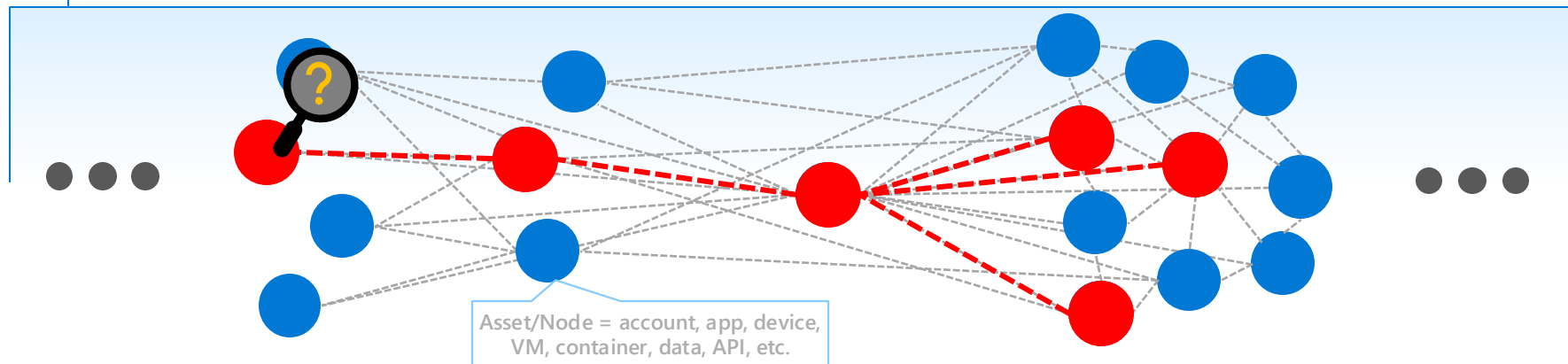
Business Enablement

Align security to the organization's mission, priorities, risks, and processes

Assume Breach (Assume Compromise)

Assume attackers can and will successfully attack anything (identity, network, device, app, infrastructure, etc.) and plan accordingly

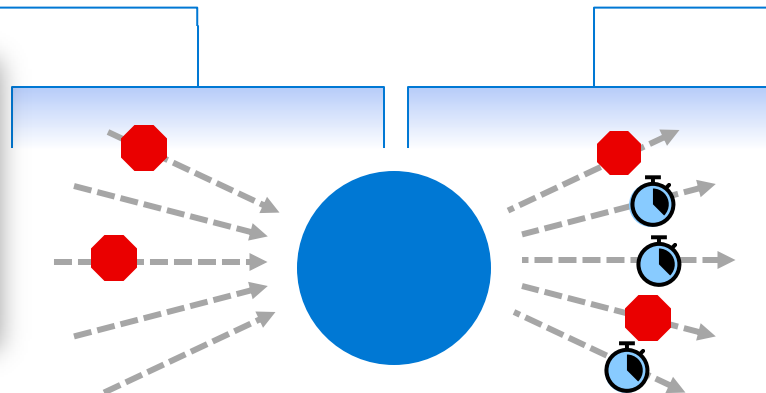
→ Transforms from *"defend the network"* to *"enable secure productivity on any network"*



Verify explicitly

Protect assets against attacker control by explicitly validating that all trust and security decisions use all relevant available information and telemetry.

→ Reduces "attack surface" of each asset



Use least privilege access

Limit access of a potentially compromised asset, typically with just-in-time and just-enough-access (JIT/JEA) and risk-based policies like adaptive access control.

→ Reduces "blast radius" of compromises

Key Industry Collaborations



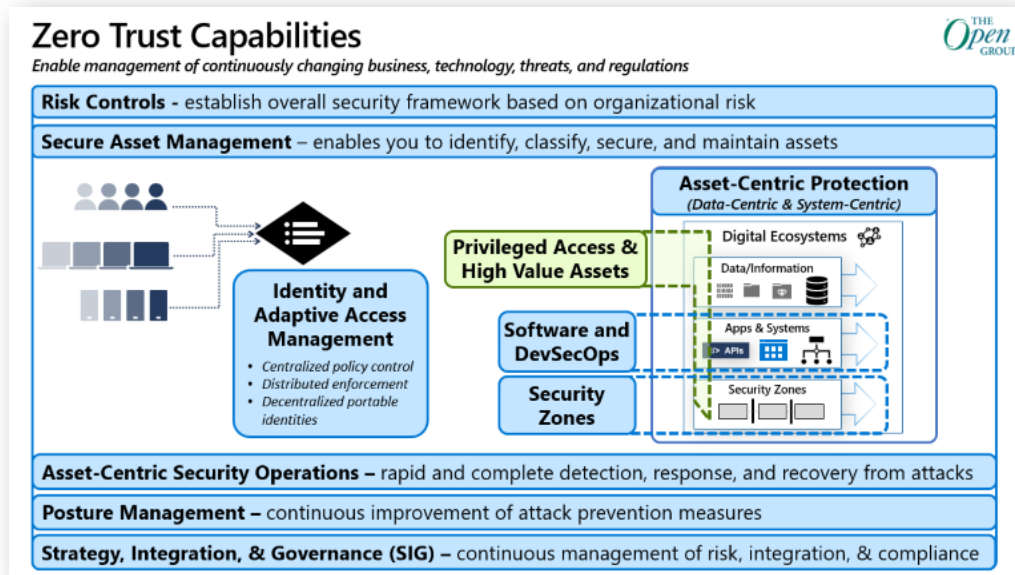
The Open Group
*Focused on integration
with business and
IT/Enterprise/Security
architecture*



**US National Institute of
Standards and
Technology (NIST)**
*Focused on architecture
and implementation with
available technology*

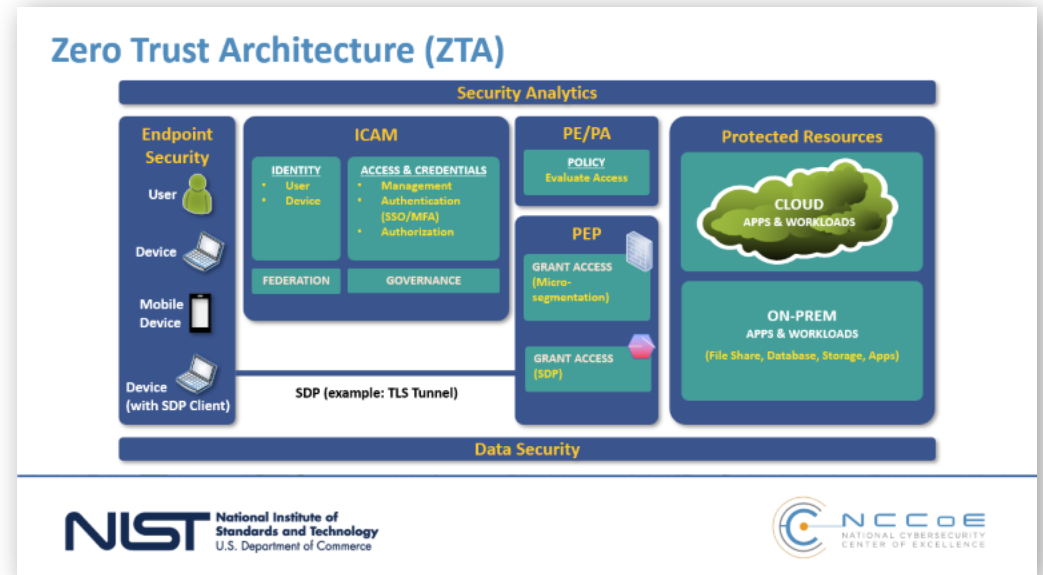
Many organizations are contributing valuable perspectives and guidance like the Cybersecurity and Infrastructure Security Agency (CISA), Cloud Security Alliance (CSA), and some technology vendors

Key Zero Trust Models and Architectures



The Open Group

Focused on integration with business and IT/Enterprise/Security architecture

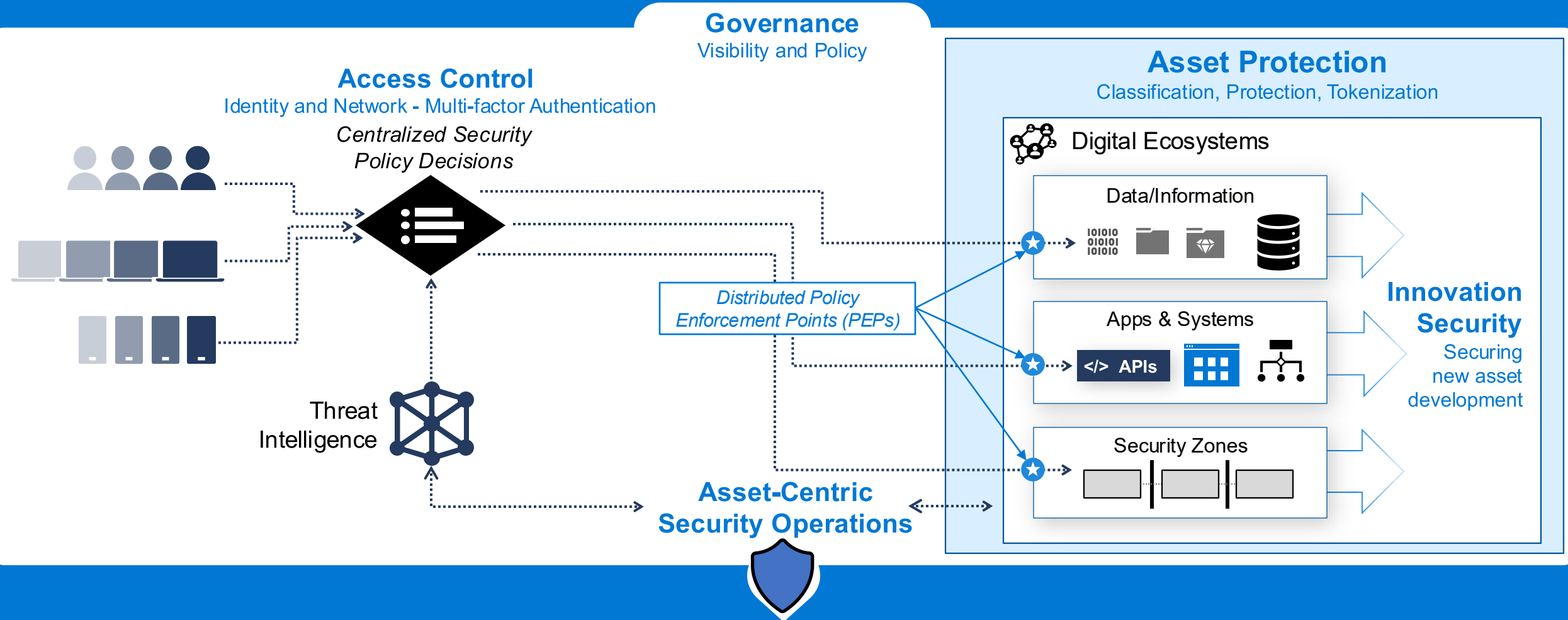


US National Institute of Standards and Technology (NIST)

Focused on architecture and implementation with available technology

Zero Trust Components

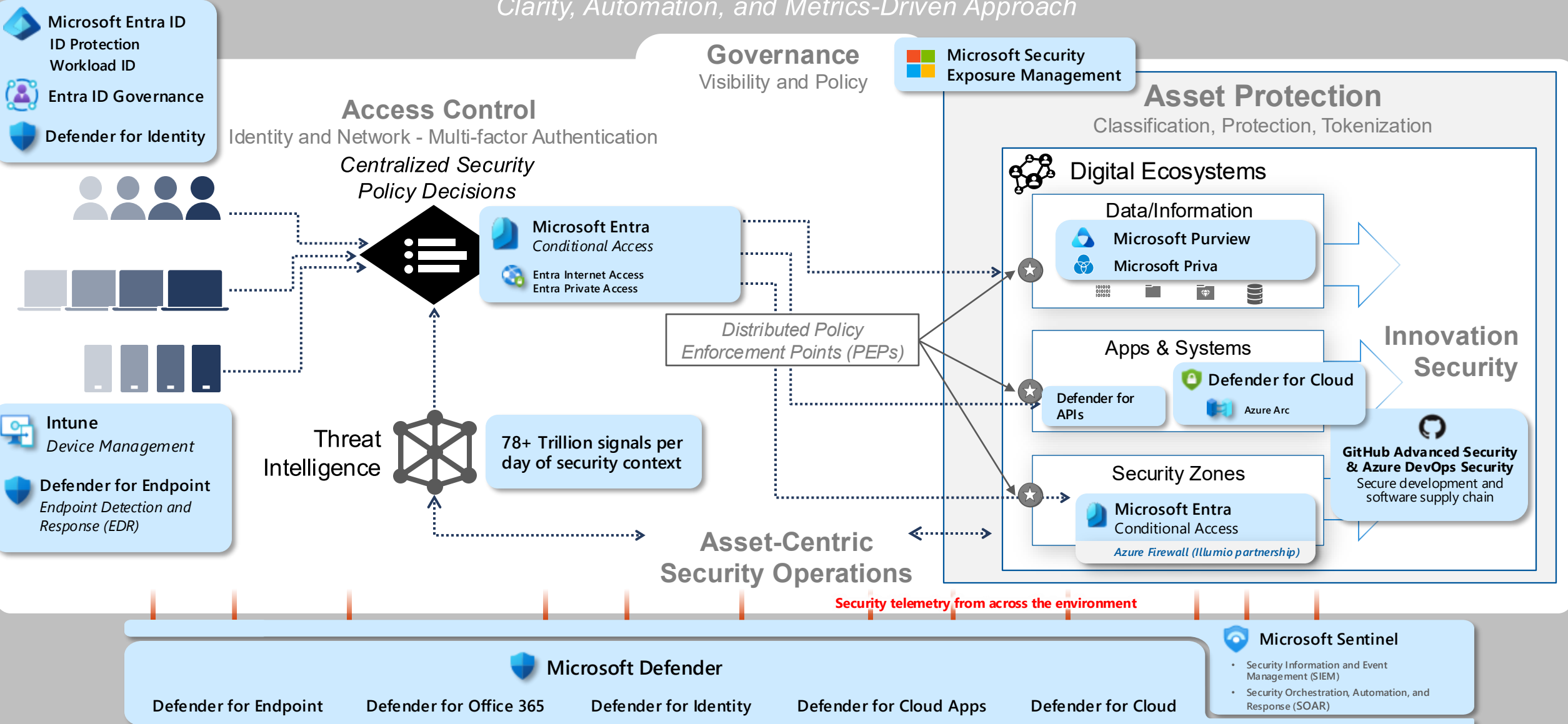
Clarity, Automation, and Metrics-Driven Approach



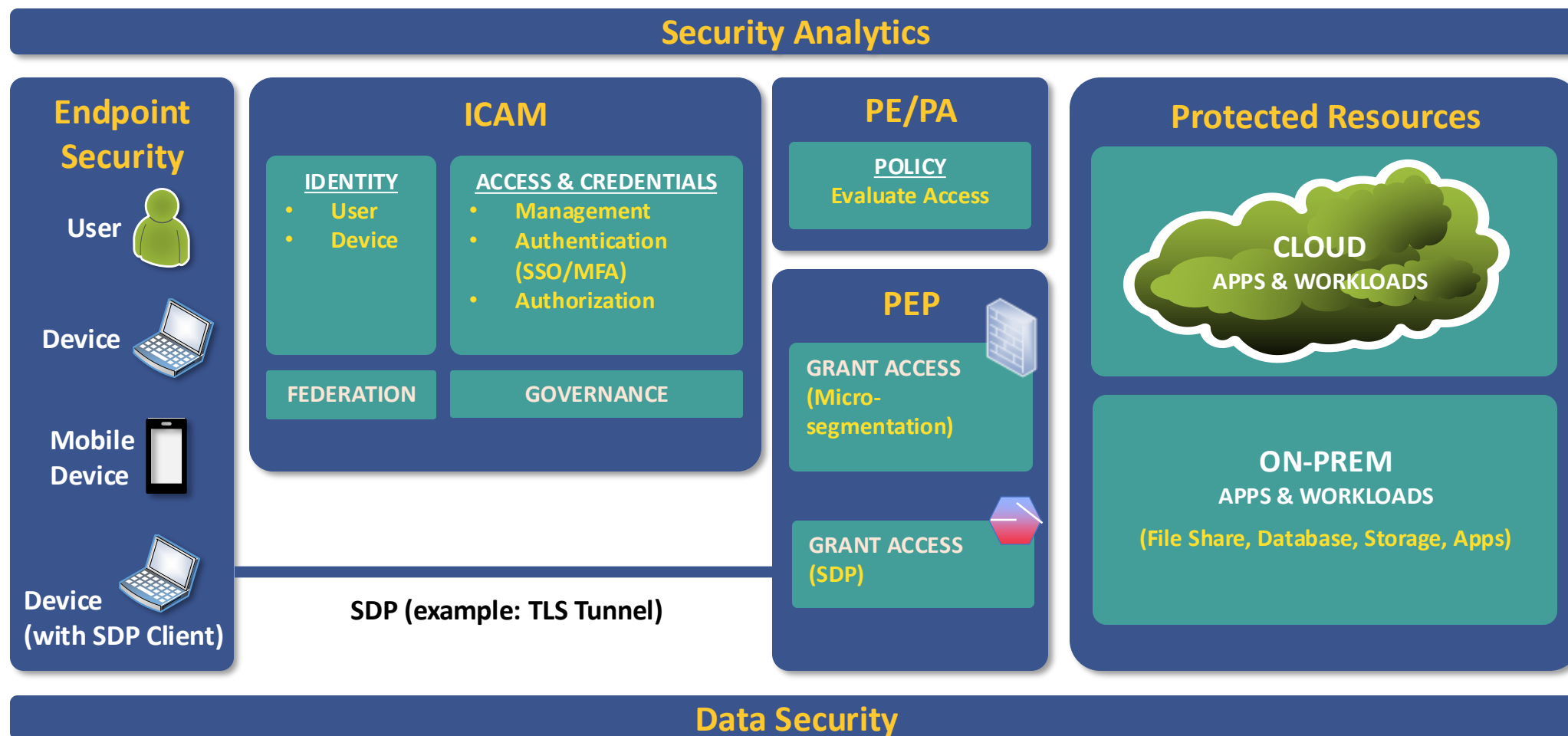
Microsoft Security Capability Mapping

The Open Group Zero Trust Components

Clarity, Automation, and Metrics-Driven Approach



Zero Trust Architecture (ZTA)



Microsoft Zero Trust Capability Mapping

Implemented as part of the [NIST ZT Architecture guide](#) (published August 2024)

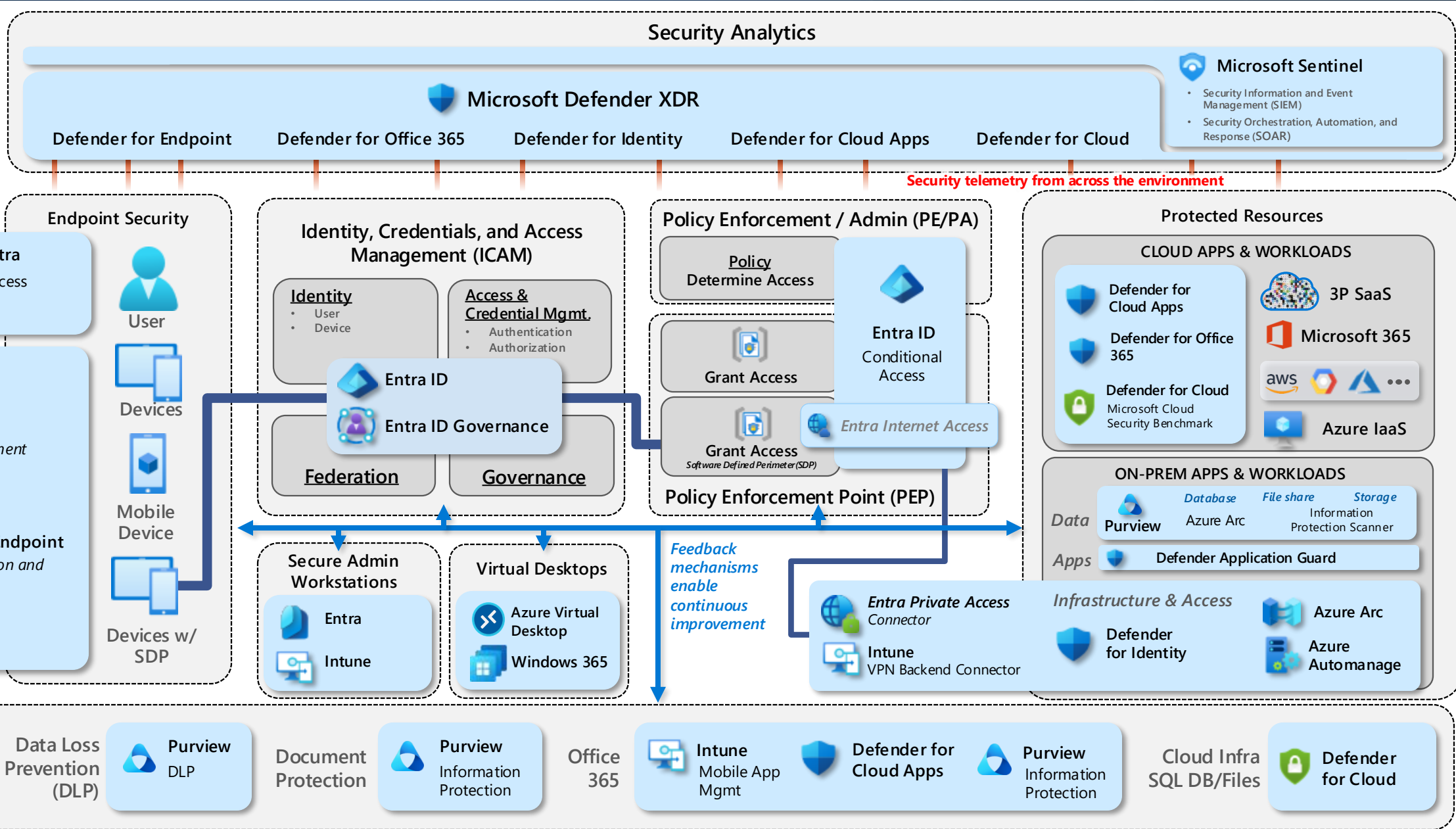
Key

NIST Area

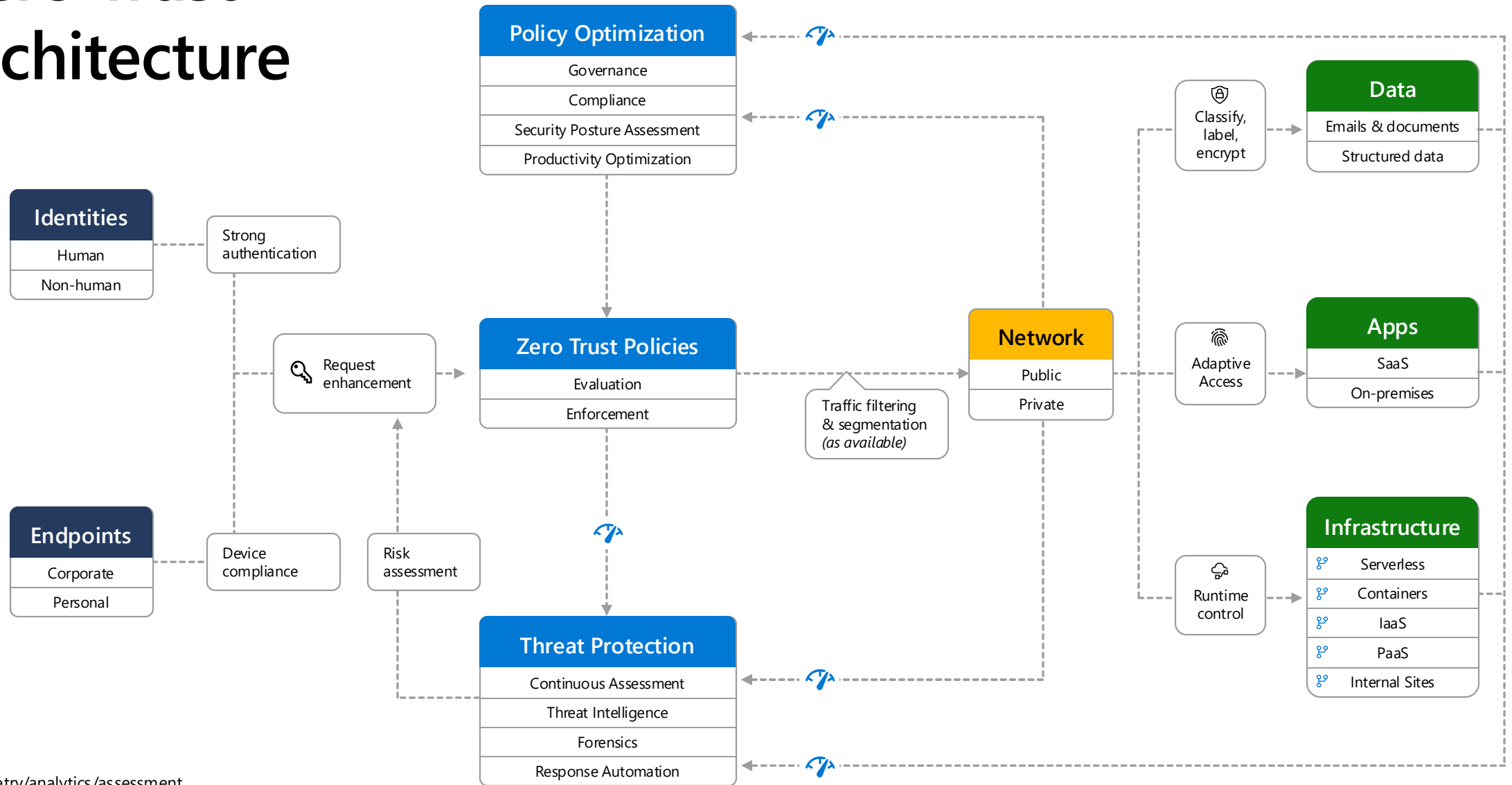
NIST Sub-Area

- Sub-Area

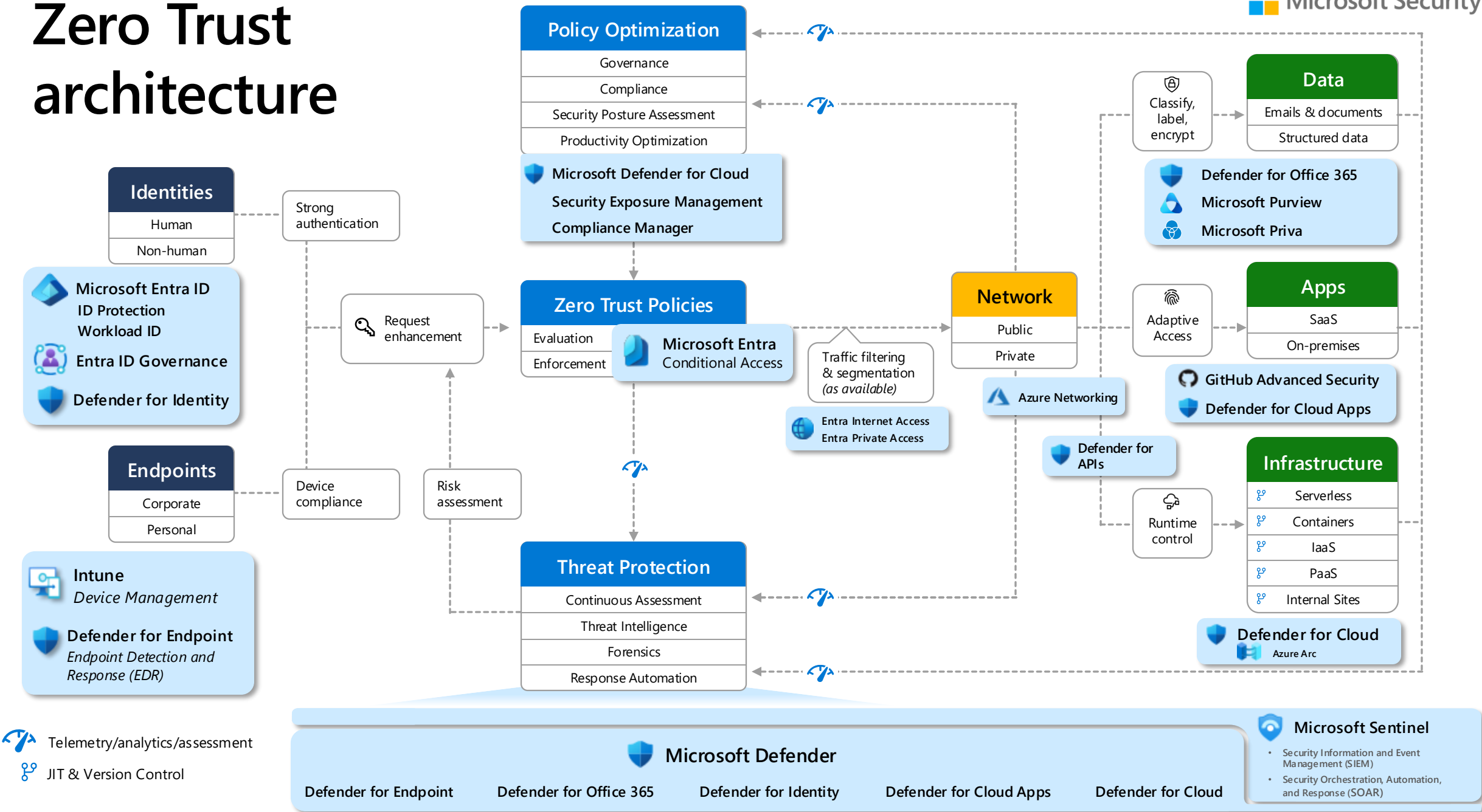
Microsoft Service



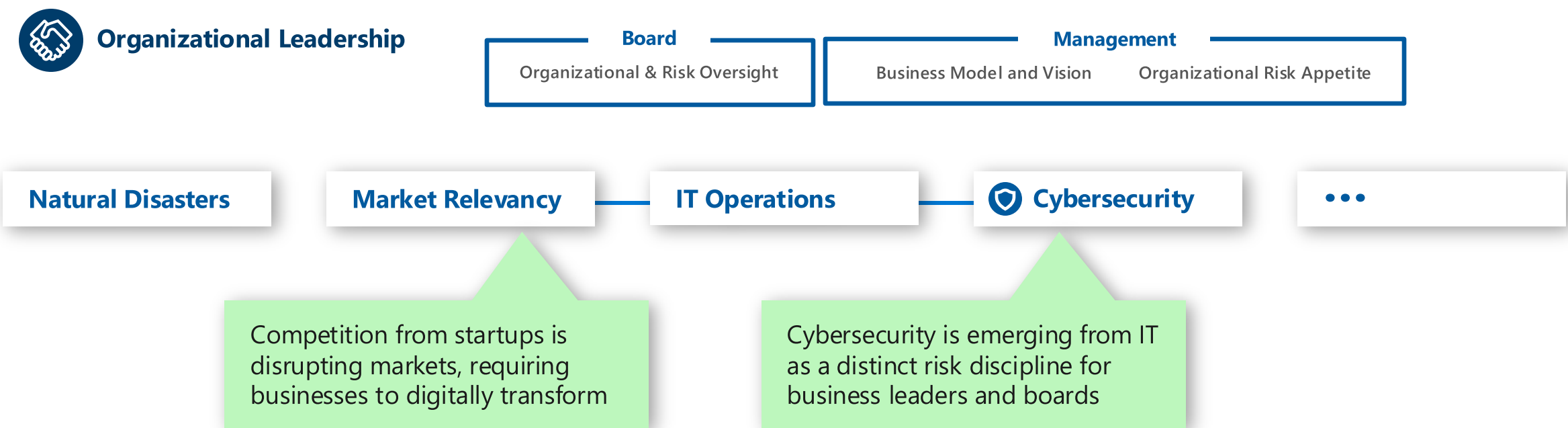
Zero Trust architecture



Zero Trust architecture



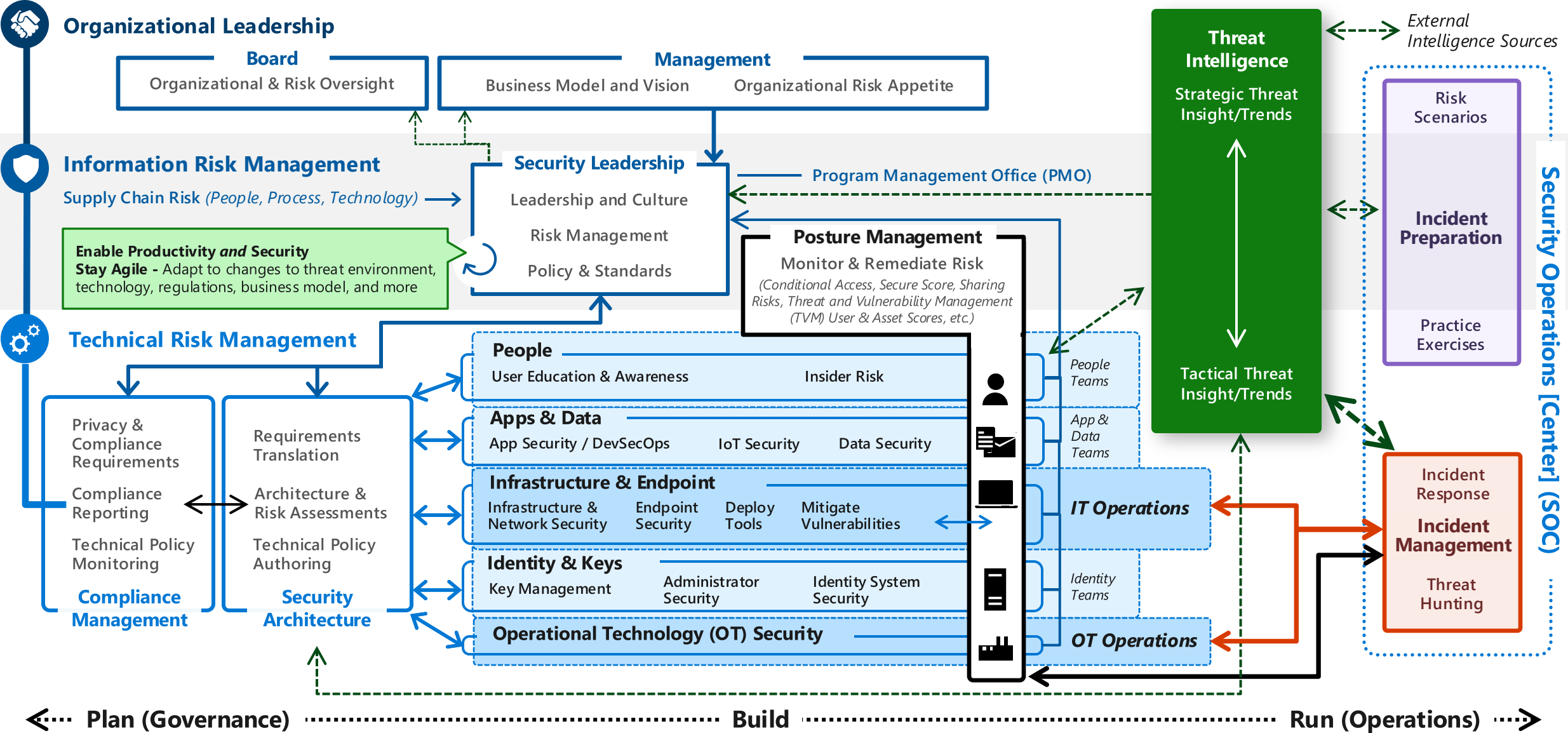
Managing organizational risk



Managing Information/Cyber Risk

Security responsibilities or "jobs to be done"

April 2025 - <https://aka.ms/SecurityRoles>



Microsoft security capability mapping

Which roles typically use which capabilities

April 2025 – <https://aka.ms/MCRA>



Access Control

Establish **Zero Trust** access model to modern and legacy assets using identity & network controls

Microsoft Entra

Identity Admin, Identity Architect, Identity Security

- **Entra ID (Formerly Azure AD)**
 - Multifactor Authentication
 - Conditional Access
 - Application Proxy
 - External Identities / B2B & B2C
 - Internet/Private Access
 - Identity Governance
 - and more..
- **Windows Hello for Business**
- **Microsoft 365 Defender**
 - Microsoft Defender for Identity
 - Microsoft Defender for Cloud Apps
- **Microsoft 365 Lighthouse** [multi-tenant]
- **Azure Lighthouse**
- **Azure Bastion**
- *Azure Administrative Model*
 - Portal, Management Groups, Subscriptions
 - Azure RBAC & ABAC
- Network Security*
 - **Azure Firewall**
 - **Azure Firewall Manager**
 - **Azure DDoS**
 - **Azure Web Application Firewall**
 - *Azure Networking Design*
 - Virtual Network, NSG, ASG, VPN, etc.
 - PrivateLink / Private EndPoint

Endpoint / Device Admin

- **Microsoft Intune**
 - Configuration Management
- **Microsoft Defender for Endpoint**



Security Operations

Detect, Respond, and Recover from attacks; Hunt for hidden threats; share threat intelligence broadly

Incident preparation

Microsoft Defender

Security Operations Analyst

Microsoft Defender XDR

- Microsoft Defender for Endpoint
- Microsoft Defender for Office 365
- Microsoft Defender for Identity
- Microsoft Defender for Cloud Apps
- Microsoft Entra Identity Protection
- **Microsoft Defender for Cloud**
 - Microsoft Defender for DevOps
 - Microsoft Defender for Servers
 - Microsoft Defender for Storage
 - Microsoft Defender for SQL
 - Microsoft Defender for Containers
 - Microsoft Defender for App Service
 - Microsoft Defender for APIs
 - Microsoft Defender for Key Vault
 - Microsoft Defender for DNS
 - Microsoft Defender for open-source relational databases
 - Microsoft Defender for Azure Cosmos DB
- **Microsoft Security Copilot**
- **Microsoft Sentinel**
- **Microsoft Security Experts**
- **Microsoft Incident Response**
 - Detection and Response Team (DART)

Threat intelligence Analyst

- **Microsoft Defender Threat Intelligence (Defender TI)**
- **Microsoft Sentinel**



Security Governance

Protect sensitive data and systems. Continuously discover, classify & secure assets

Security architecture

- Microsoft Cybersecurity Reference Architecture <https://aka.ms/MCRA>

Posture management, Policy and standards, Compliance management

- **Microsoft Defender for Cloud**
 - Secure Score
 - Compliance Dashboard
 - Azure Security Benchmark
- **Azure Blueprints**
- **Azure Policy**
- **Microsoft Defender External Attack Surface Management (MD-EASM)**
 - Azure Administrative Model
 - Portal, Management Groups, Subscriptions
 - Azure RBAC & ABAC
- **Microsoft Purview**
 - Compliance manager

Data security

- **Microsoft Purview**
 - Information Protection
 - Data Loss Prevention
- **Microsoft 365 Defender**
 - Microsoft Defender for Cloud Apps

People security

- **Attack Simulator**
- **Insider Risk Management**

Privacy Manager

- **Microsoft Priva**

Microsoft Purview



Asset Protection

Continuously **Identify**, measure, and manage security posture to reduce risk & maintain compliance

Infrastructure and endpoint security, IT Ops, DevOps

- **Microsoft Defender for Cloud** (including Azure Arc)
- **Azure Blueprints**
- **Azure Policy**
- **Azure Firewall**
- **Azure Monitor**
- **Azure Web Application Firewall**
- **Azure DDoS**
- **Azure Backup and Site Recovery**
 - *Azure Networking Design*
 - Virtual Network, NSG, ASG, VPN, etc.
 - PrivateLink / Private EndPoint
- **Azure Resource Locks**

OT and IoT Security

- **Microsoft Defender for IoT (& OT)**
- **Azure Sphere**



Innovation Security

Integrate Security into DevSecOps processes. Align security, development, and operations practices.

Application security and DevSecOps

- (Same as Infrastructure Roles)
- **GitHub Advanced Security**
- **Azure DevOps Security**

Security accountabilities & responsibilities across the organization

Organizational Leadership & Oversight

- Member of Board of Directors
- Chief Executive Officer (CEO)
- Chief Financial Officer (CFO)
- Chief Operating Officer (COO)
- Chief Legal Officer (CLO)
- Product and Business Line Leaders

Business Management and Operations

- Product Line Managers / Directors
- Product Owners
- Business Architects
- Business Analysts
- Information Worker / Frontline Worker

Security-Adjacent Disciplines

- Chief Security Officer (CSO) and team
- Chief Risk Officer (CRO) and team
- Chief Privacy Officer (CPO) and team
- Data Officer / Data Governance and team
- Compliance and Audit team
- Anti-Fraud Team

Other Cross-Functional Disciplines

- Legal Team
- Finance Team
- Procurement & Acquisition
- Human Resources
- Communications / Public Relations
- Organizational Readiness / Training

Technical Leadership

- Chief Digital Officer (CDO)
- Chief Information Officer (CIO)
- Chief Technology Officer (CTO)
- Chief Information Security Officer (CISO)
- Software Delivery Vice President (VP)
- Technology Directors
- Security Directors
- Security Strategy, Integration, and Governance
- Software Development Directors

Architects

- Enterprise Architects
- Security Architects
- Infrastructure Architects
- Data and Artificial Intelligence (AI) Architects
- Access Architects (Identity, Network, App, etc.)
- Solution Architects
- Software / Application Architects

Application & Product Development

- Technology Delivery Managers
- Software Testing/Quality Managers
- Software Security Engineers
- Software Developers (including AI)
- Software Testers
- DevOps Leads
- Supply Chain Security
- Internet of Things (IoT)

People Security

- Security Education and Engagement
- Insider Risk Management

Security Posture Management

- Security Posture Management
- Security Governance & Compliance Management

Technical Engineering and Operations

- Technology Managers
- Security Managers
- Automation Engineering
- Identity
- Network
- User Endpoints
- User Productivity and Support
- Infrastructure/Platform (Cloud, On-Prem, CI/CD, etc.)
- Data and Artificial Intelligence (AI)
- Operational Technology (OT)
- Security Engineering

Security Operations (SecOps/SOC)

- Security Operations (SecOps) Managers
- Triage Analyst
- Investigation Analyst (Digital Forensics)
- Reverse Engineering
- Threat Hunting and Detection Engineering
- SecOps Platform and Data Engineering
- Attack Simulation (Red & Purple Teaming)
- Incident Coordination and Management
- Threat Intelligence

Role Example – CEO

Security responsibilities/accountabilities

Chief Executive Officer (CEO) – The CEO establishes the culture and strategic direction of the organization that guides everyone in the organization on how to prioritize funding, time, and energy across all aspects of the business, including security risk. The security accountabilities for a CEO include:

- **Prioritizing security** in the organization's culture and sponsoring the Zero Trust transformation by embedding security in business decisions at all levels (which may require shifting revenue vs. risk tradeoffs).
- **Establish or correct security accountability structure** - The CEO must ensure that anyone making a decision that impacts the organization's security risk is accountable for the full consequence of those decisions including the security risk implications of them.
- **Position security team as an enabler** - The CEO must empower the CISO and security team to provide the required security context to business and technology roles across the organization (and hold them accountable for this enablement). This includes providing expertise to enable risk prevention, management of incidents that do happen, and supporting the continuous learning by providing tailored recommendations to avoid or mitigate future incidents.
- **Sponsor or approve security-aware procurement and open source policy** - The CEO must ensure that organizational policy requires analyzing the security characteristics of all new software before the organization commits to purchasing or integrating it into their systems. Any software can introduce organizational risk if it isn't properly developed, tested, implemented, and maintained. A security review of software and vendors can discover and mitigate security risks early and cost-effectively before the organization has invested into product implementation and integration.

This must be applied generally to all procurement because software is included in a high percentage of products purchased by organizations (including many different types and sizes of equipment). Additionally, most technology and AI projects typically include open source software that can introduce security risks to the organization (outside of purchasing process)

Consequences of not doing this (or well /completely)

Without the CEO prioritizing cybersecurity across the organization, the security team is often positioned as a scapegoat, getting the accountability and blame for security incidents resulting from decisions made by other teams. This causes all non-security roles to lack understanding and accountability for the security impacts of decisions they make, resulting in higher risk with every decision and action.

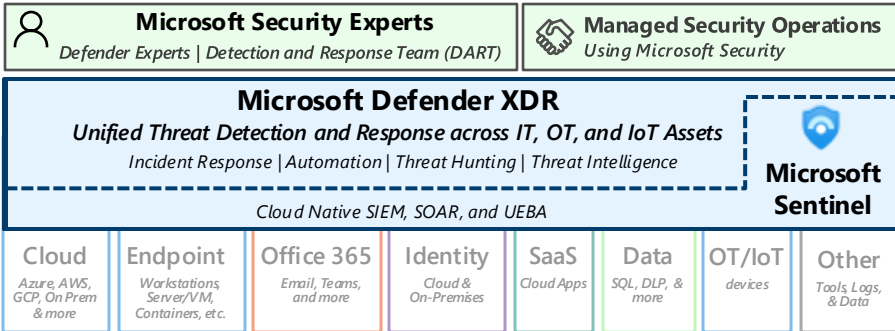
This results in more security incidents, higher severity and business impact per incident, inability to accurately judge the organization's actual risk, inability to recruit security leaders / professionals, and reduced business agility because security teams often try to slow or block business initiatives for fear of being blamed.

Asset Scope and Required Attack Knowledge

The CEO is ultimately accountable for all organizational assets of all types in aggregate.

- Standard cybersecurity skills for information workers
- Organizational security threats, risks, and challenges

Security Operations (SecOps/SOC)



Cybersecurity Reference Architecture

Security modernization with Zero Trust Principles

April 2025 – aka.ms/MCRA

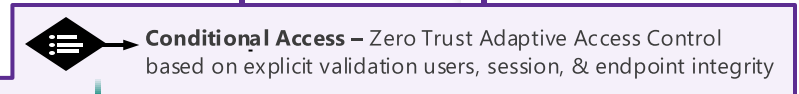
This is interactive!

1. Present Slide
2. Hover for Description
3. Click for more information

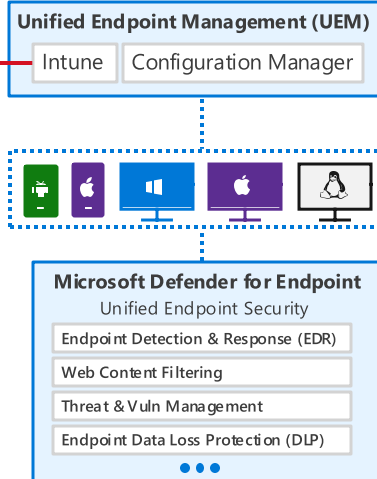
Security Guidance

1. [Security Adoption Framework](#)
2. [Security Documentation](#)
3. Cloud Security [Benchmarks](#)

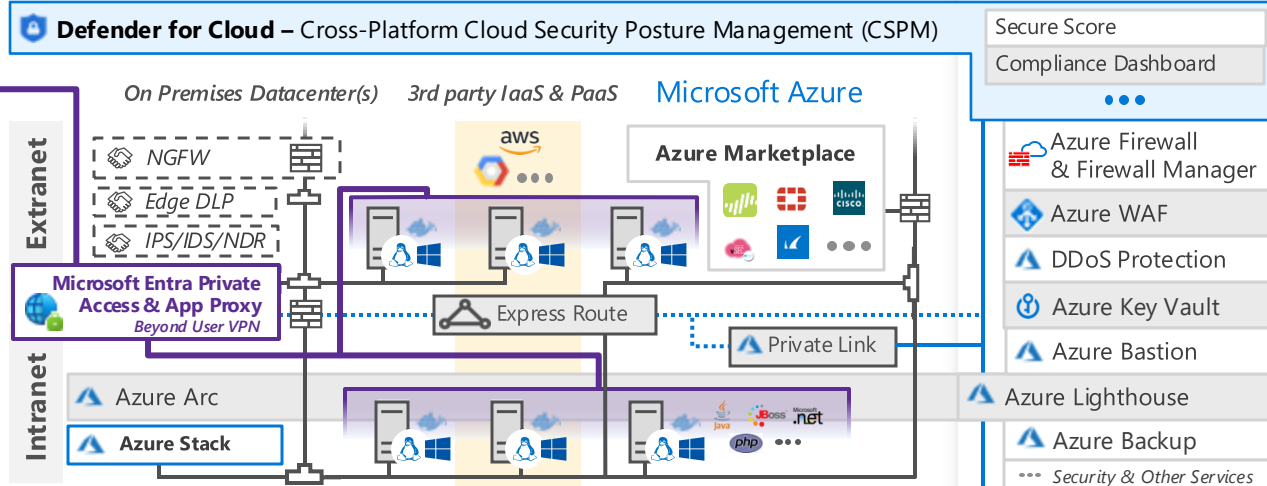
Software as a Service (SaaS)



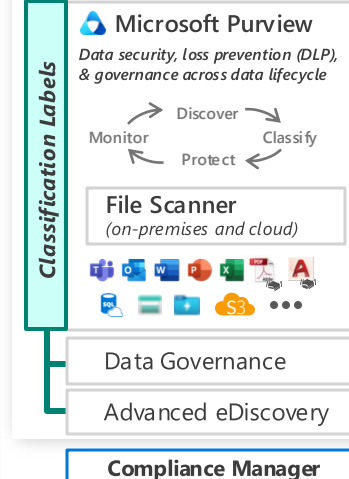
Endpoints & Devices



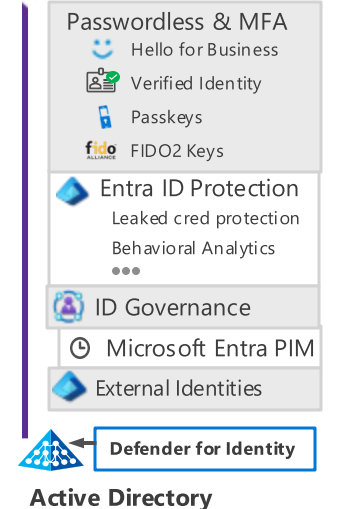
Hybrid Infrastructure – IaaS, PaaS, On-Premises



Information Protection



Microsoft Entra



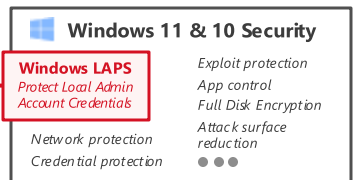
Securing Privileged Access – aka.ms/SPA

Privileged Access Workstations (PAWs) - Secure workstations for administrators, developers, and other sensitive users

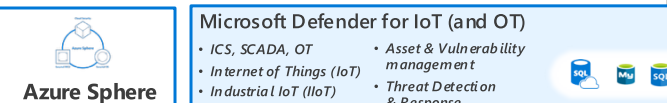
Privileged Access Management (PAM)

Cloud Infrastructure Entitlement Management (CIEM)

Microsoft Security Exposure Management – Provides unified view of security posture + attack surface across organization, enabling you to investigate security insights, identify critical assets, reduce attack surfaces and security risk



IoT and Operational Technology (OT)



Defender for Cloud – Cross-Platform, Multi-Cloud XDR
Detection and response capabilities for infrastructure and development across IaaS, PaaS, and on-premises

Defender for APIs

People Security

Attack Simulator **Insider Risk Management** **Communication Compliance**

GitHub Advanced Security & Azure DevOps Security
Secure development and software supply chain

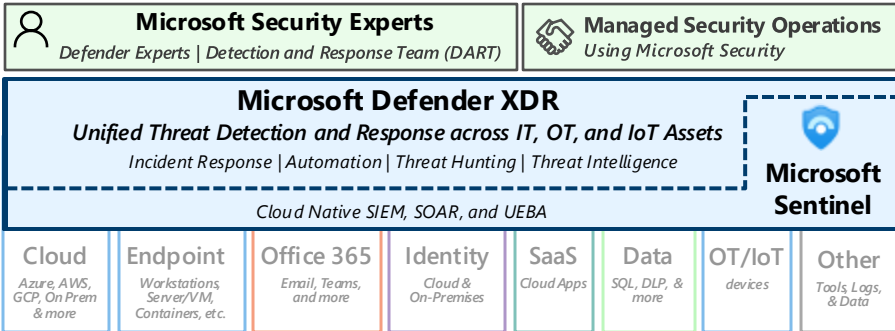
Microsoft Security Copilot

Threat Intelligence – 78+ Trillion signals per day of security context

Service Trust Portal – How Microsoft secures cloud services

Security Development Lifecycle (SDL)

Security Operations (SecOps/SOC)



Cybersecurity Reference Architecture

Security modernization with Zero Trust Principles

April 2025 – aka.ms/MCRA

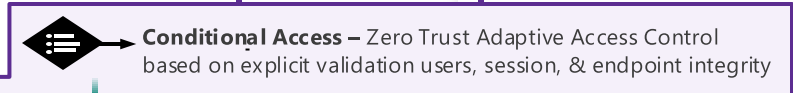
This is interactive!

1. Present Slide
2. Hover for Description
3. Click for more information

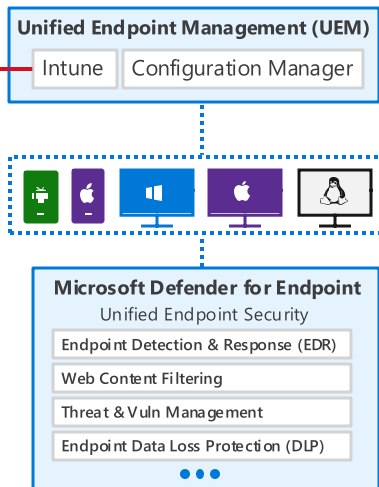
Security Guidance

1. [Security Adoption Framework](#)
2. [Security Documentation](#)
3. Cloud Security [Benchmarks](#)

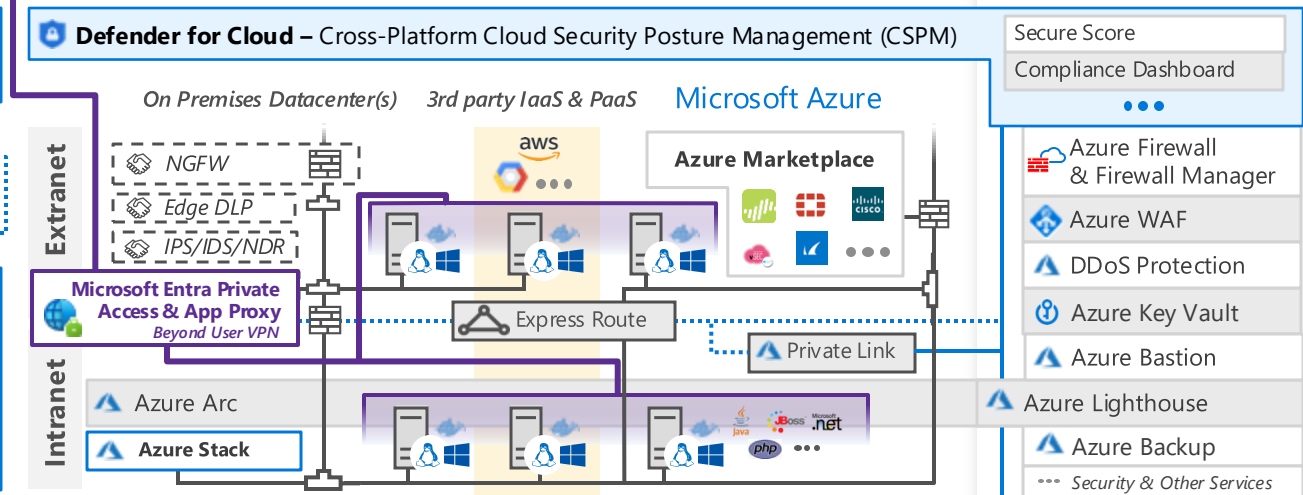
Software as a Service (SaaS)



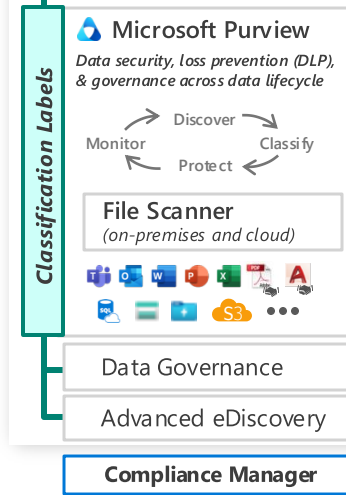
Endpoints & Devices



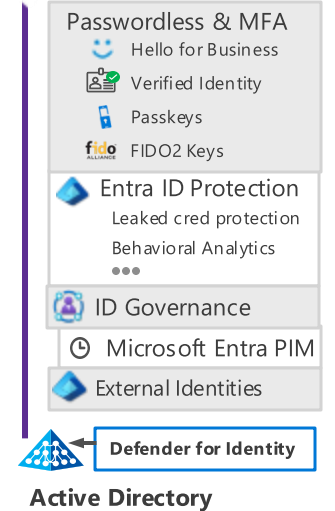
Hybrid Infrastructure – IaaS, PaaS, On-Premises



Information Protection



Microsoft Entra



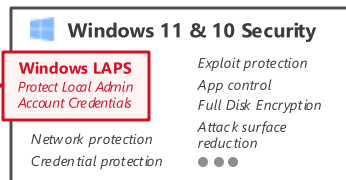
Securing Privileged Access – aka.ms/SPA

Privileged Access Workstations (PAWs) - Secure workstations for administrators, developers, and other sensitive users

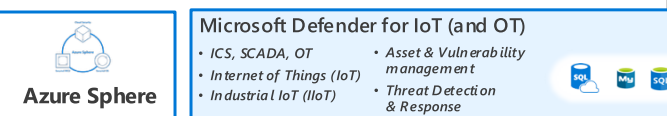
Privileged Access Management (PAM)

Cloud Infrastructure Entitlement Management (CIEM)

Microsoft Security Exposure Management – Provides unified view of security posture + attack surface across organization, enabling you to investigate security insights, identify critical assets, reduce attack surfaces and security risk



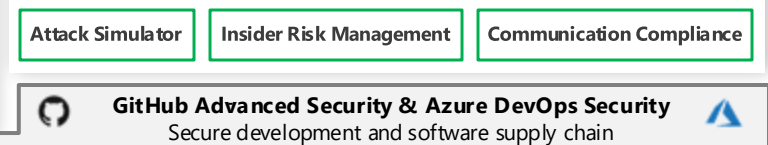
IoT and Operational Technology (OT)



Defender for Cloud – Cross-Platform, Multi-Cloud XDR
Detection and response capabilities for infrastructure and development across IaaS, PaaS, and on-premises

Defender for APIs

People Security



Microsoft Security Copilot

Threat Intelligence – 78+ Trillion signals per day of security context

Service Trust Portal – How Microsoft secures cloud services

Security Development Lifecycle (SDL)

Cross-cloud and cross-platform

Comprehensive Security, Compliance and Identity capabilities that integrate with your existing solutions



April 2025
<https://aka.ms/MCRA>

Industry Partnerships

NIST / CIS / The Open Group / Others Microsoft Intelligent Security Association Solution Integration and MDR/MSSP Partners CERTs / ISACs / Others Law Enforcement ...



Microsoft Security, Compliance, and Identity Capabilities

Threat Intelligence – 78+ Trillion signals per day of security context

Access Control

Identity and Network

Modern Security Operations

Rapid Resolution with XDR, SIEM, SOAR, UEBA and more

Asset Protection

Information Protection and App Security / DevSecOps

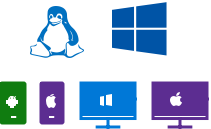
Technical Governance

Risk Visibility, Scoring, and Policy Enforcement

People Security – User Education/Empowerment and Insider Threats



Endpoints & Devices



Software as a Service (SaaS)



Hybrid Infrastructure – IaaS, PaaS, On-Premises



IoT Devices



Operational Technology (OT)

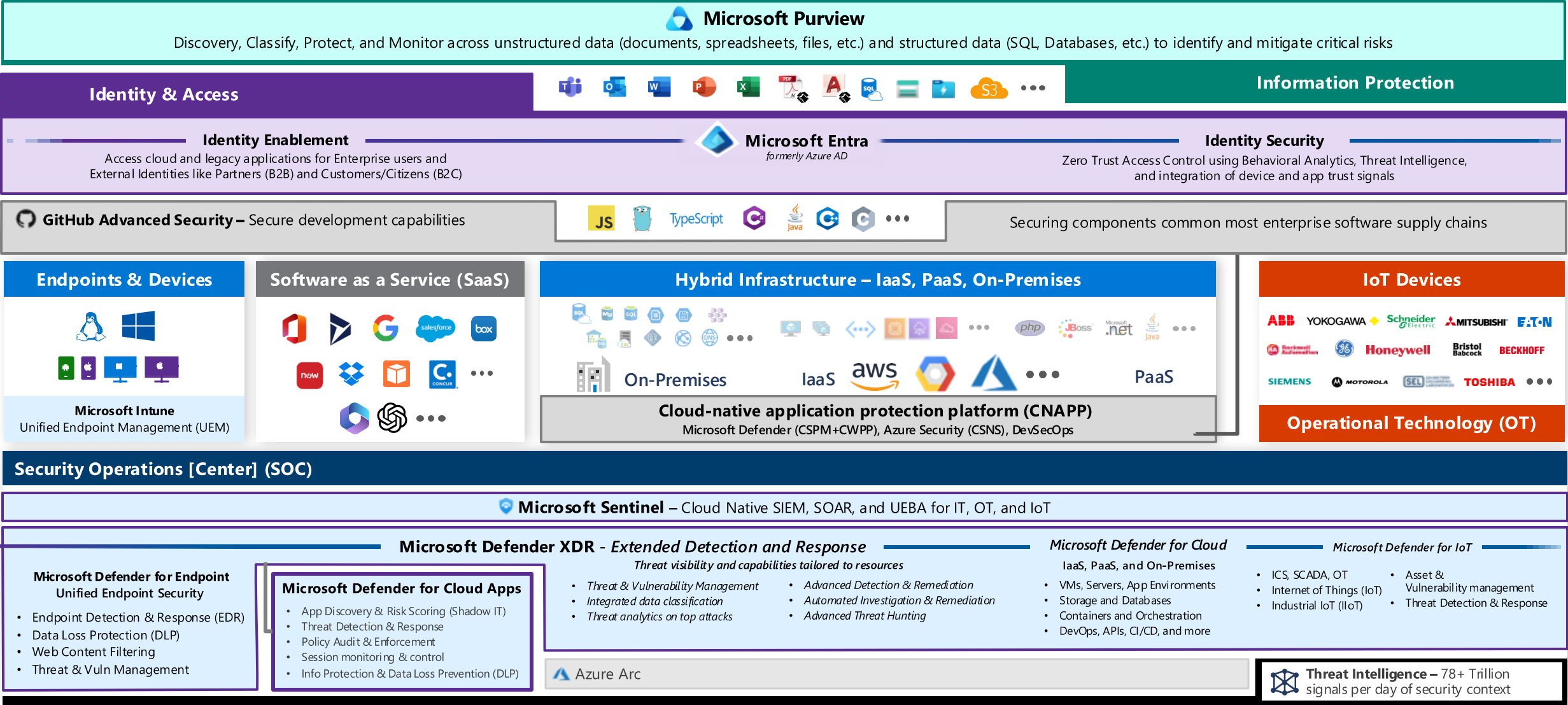
Security Operations [Center] (SOC) – Reduce attacker time/opportunity to impact business

Multi-Cloud and Cross-Platform Technology

Secure the enterprise you have



April 2025
<https://aka.ms/MCRA>

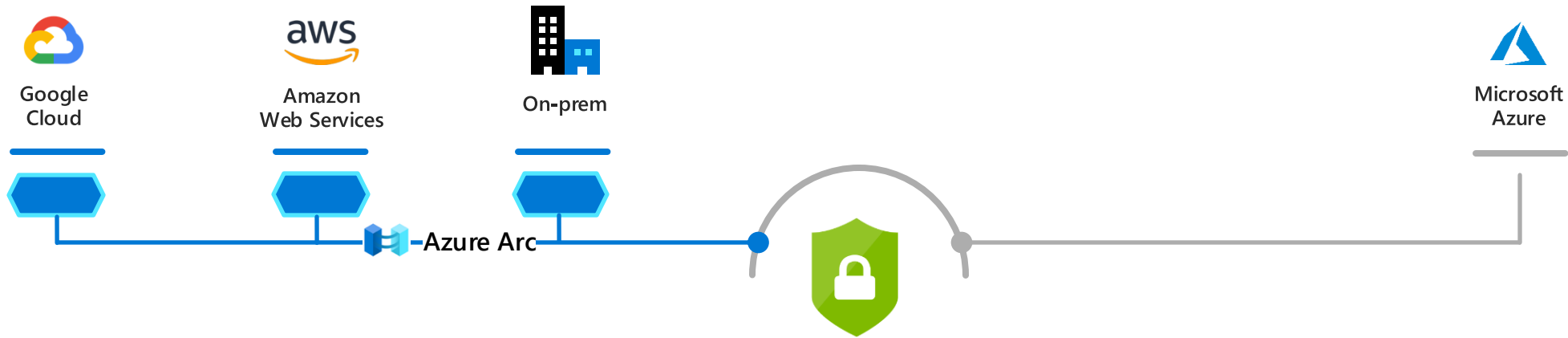


Key cross-platform and multi-cloud guidance

- [Microsoft Defender for Cloud multicloud solution](#)
- [Microsoft Defender for Endpoint – Linux Support](#)
- [Azure security solutions for AWS](#)
- [Entra ID identity and access management for AWS](#)

The image is a collage of several Microsoft documentation pages. At the top right, a page titled 'Defender for Cloud for your multicloud environment' describes how Microsoft Defender for Cloud connects to multicloud environments. Below it, three side-by-side cards show 'About multicloud deployments', 'Defend Amazon AWS resources', and 'Defend Google GCP resources'. In the center, a page for 'Microsoft Defender for Endpoint for Linux' provides an overview and installation instructions. At the bottom left, a page titled 'Azure security solutions for AWS' discusses integrating Azure security with AWS. Below that, a page for 'Azure AD identity and access management for AWS' details how to use Azure Active Directory for AWS identity management. At the bottom right, a page titled 'How to install Microsoft Defender for Endpoint for Linux' lists prerequisites and installation steps. A diagram at the bottom center illustrates the 'Benefits' of integrating Microsoft security solutions with 'Amazon Web Services', showing a flow from AWS Management Console to AWS resources and then to various security services like Azure AD, Azure Sentinel, and Azure Security Center.

Multi-cloud & hybrid protection in Microsoft Defender for Cloud



Security posture
& compliance

Secure score

Asset management

Policy



Server protection
(Microsoft Defender for Cloud for VMs)

Threat detection

Vulnerability Assessment

Application control



Automation &
management at scale

Automation

SIEM integration

Export

Access Management Capabilities

Adaptive Access applying Zero Trust Principles

Legend

.....

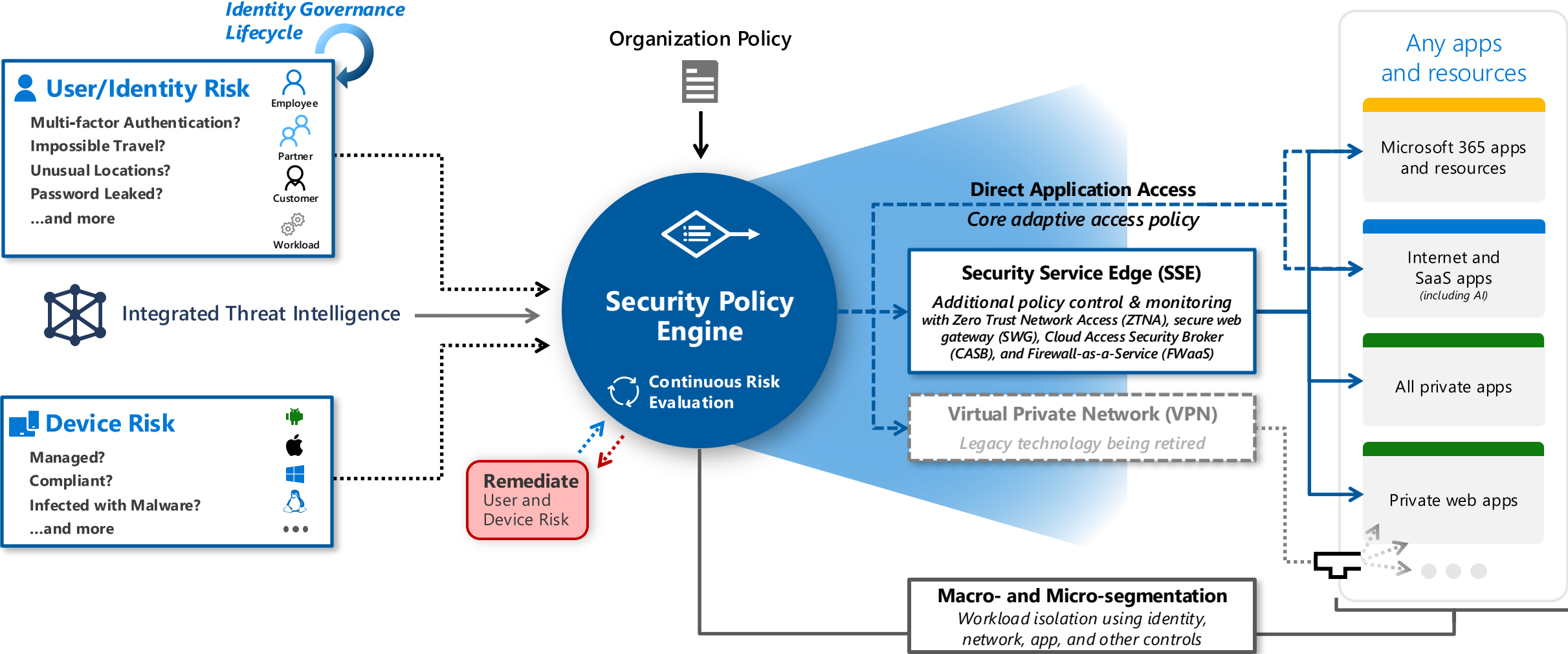
Trust Signal

Threat Intelligence

Adaptive Access Policy

Additional Policy & Monitoring

Can be implemented today using Microsoft and partner capabilities



Signal

to make an informed decision



Decision

based on organizational policy



Enablement and Enforcement

of policy across resources

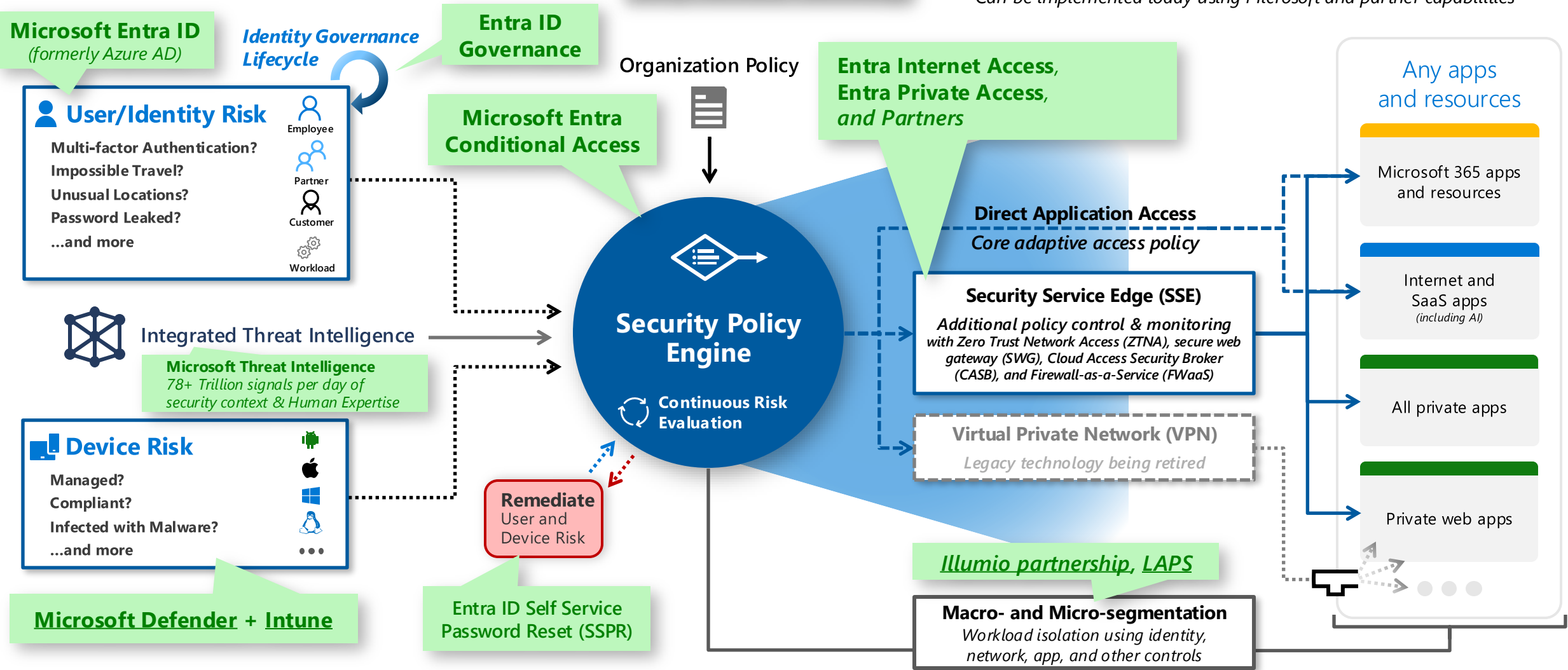
Access Management Capabilities

Adaptive Access applying Zero Trust Principles *Using Microsoft Technology*

Legend

- Trust Signal
- Adaptive Access Policy
- Threat Intelligence
- Additional Policy & Monitoring

Can be implemented today using Microsoft and partner capabilities



Signal

to make an informed decision



Decision

based on organizational policy

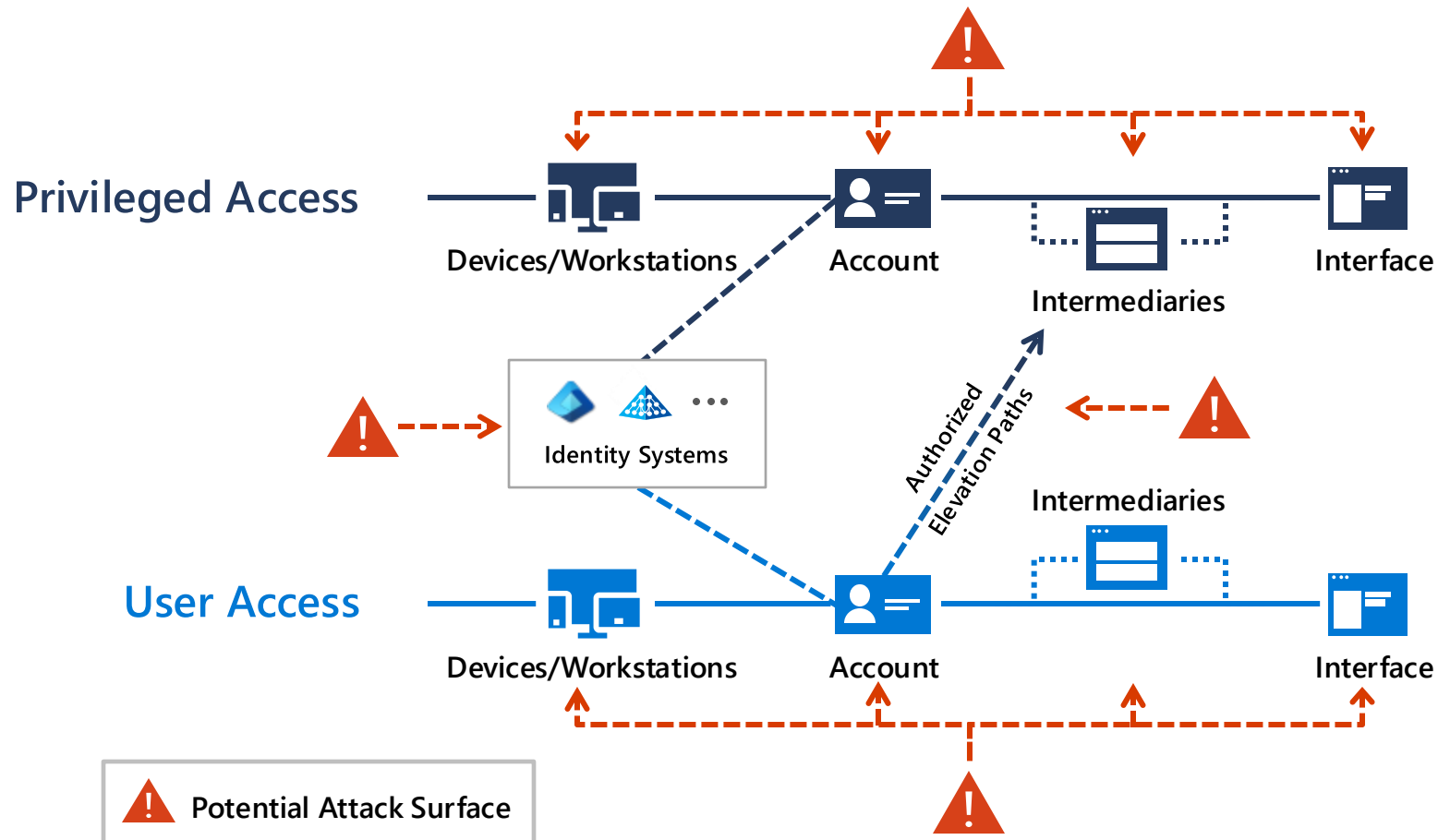


Enablement and Enforcement

of policy across resources

Attackers have options

to compromise privileged access



Business Critical Assets

Across On-Premises, Cloud, OT, & IoT



Identity Systems



Cloud Service Admin

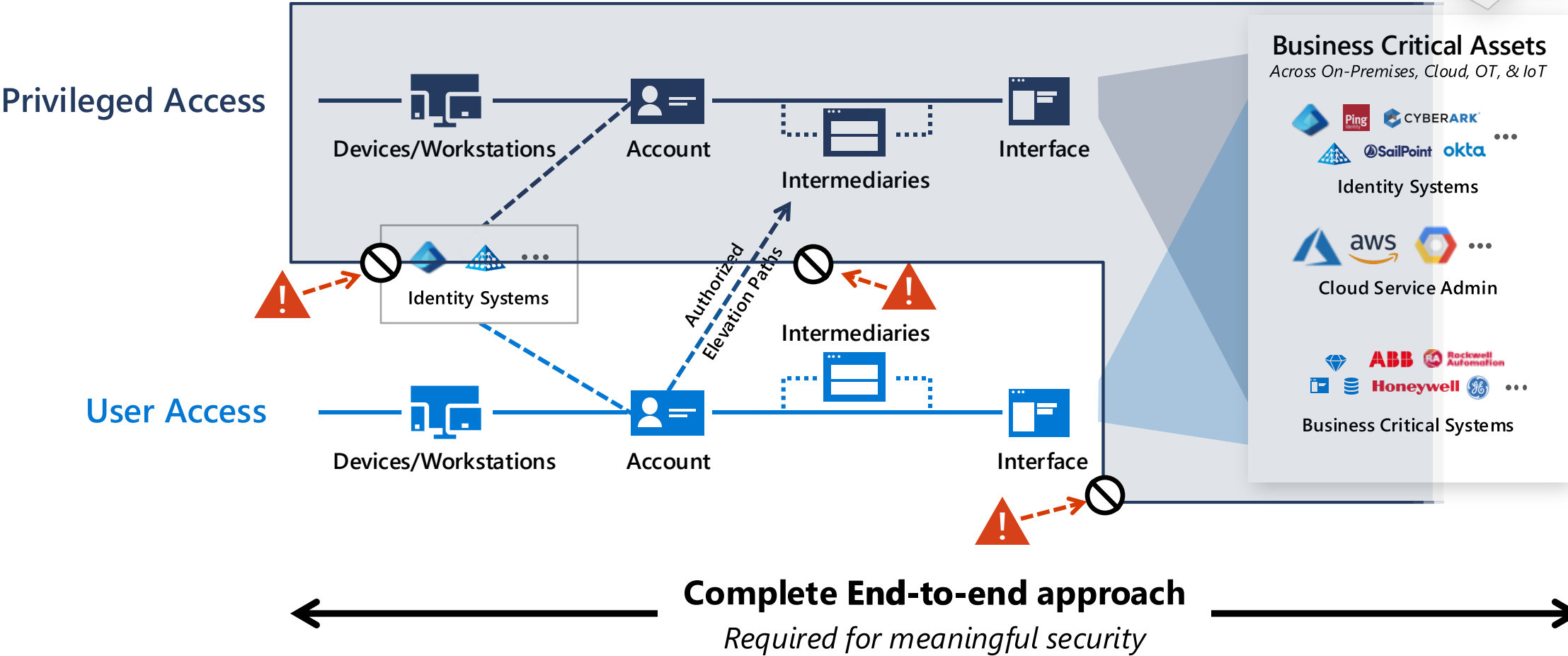


Business Critical Systems

Limit and protect pathways to privileged access

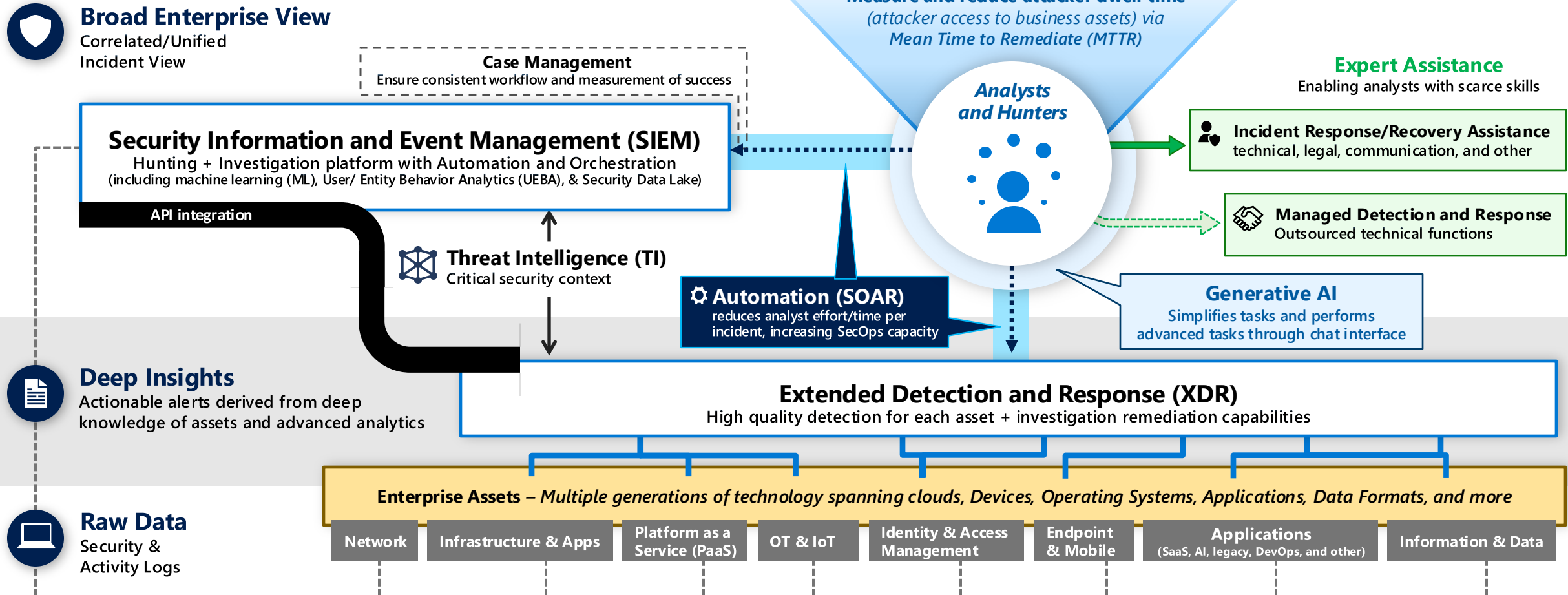
Prevention and rapid response

Asset Protection also required
*Security updates, DevSecOps,
data at rest / in transit, etc.*



Security Operations Capabilities

Enabling a people-centric function focused rapid remediation of realized risk



Security Operations

Microsoft Reference Architecture

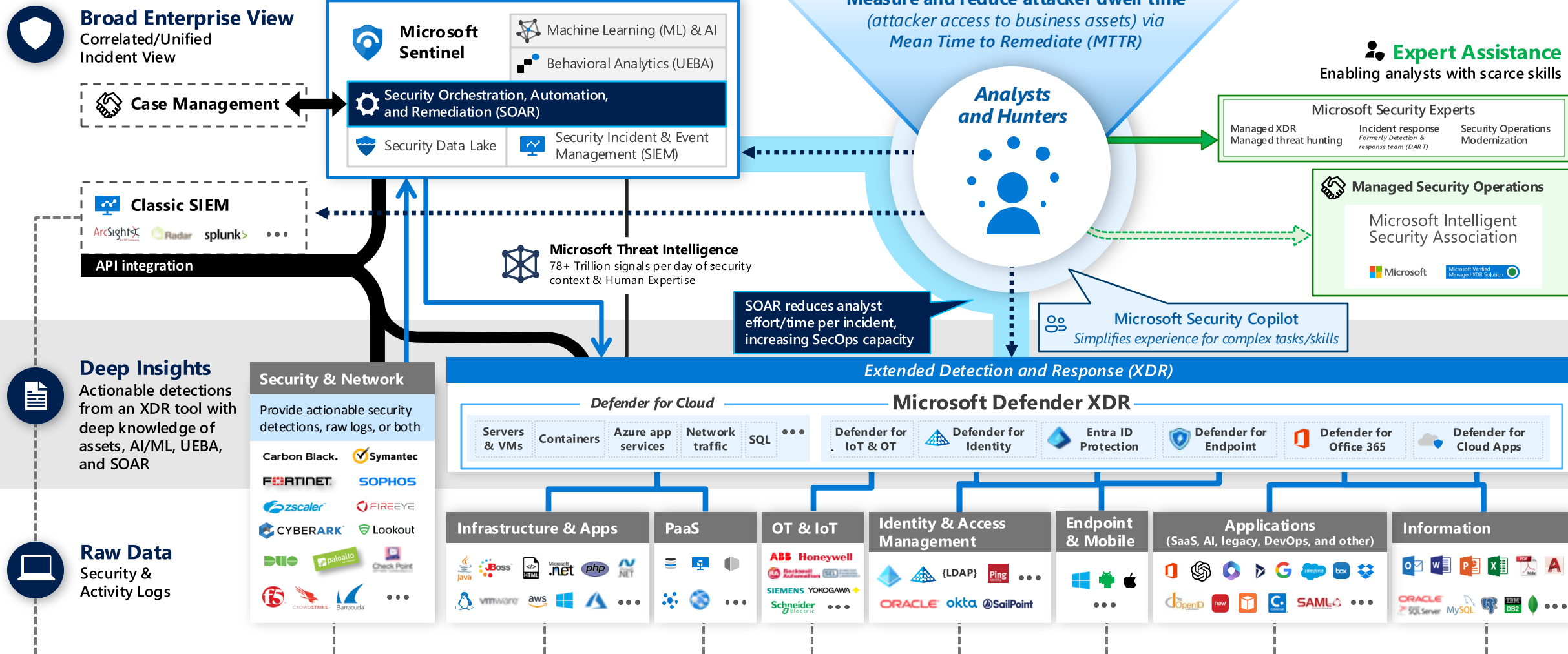
Legend

- Event Log Based Monitoring
- Investigation & Proactive Hunting

- Outsourcing
- Consulting and Escalation
- Native Resource Monitoring



April 2025 – <https://aka.ms/MCRA>

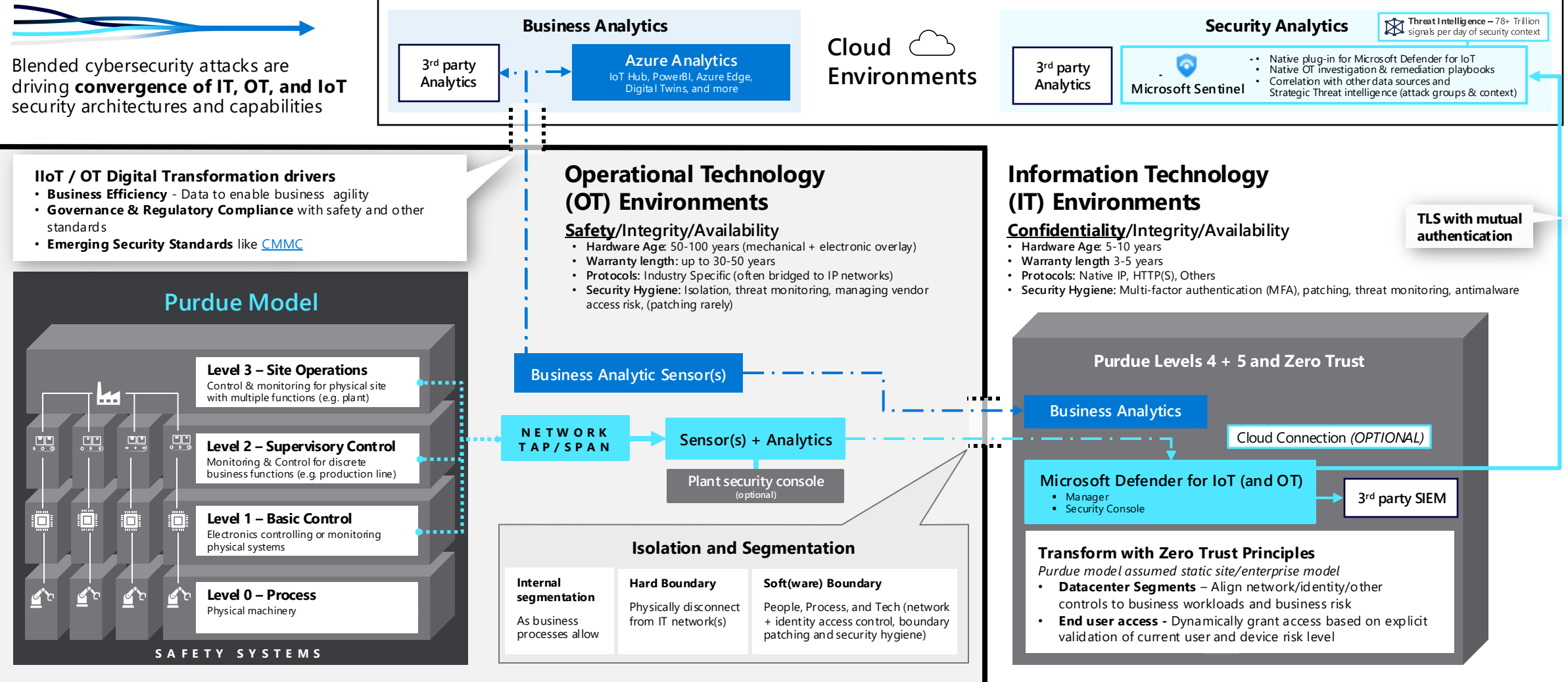


Operational Technology (OT) Security Reference Architecture

Apply zero trust principles to securing OT and industrial IoT environments



April 2025 –
<https://aka.ms/MCRA>



Zero Trust Principles - Assume breach, verify explicitly, Use least privilege access (identity and network)

Infrastructure Security Capabilities

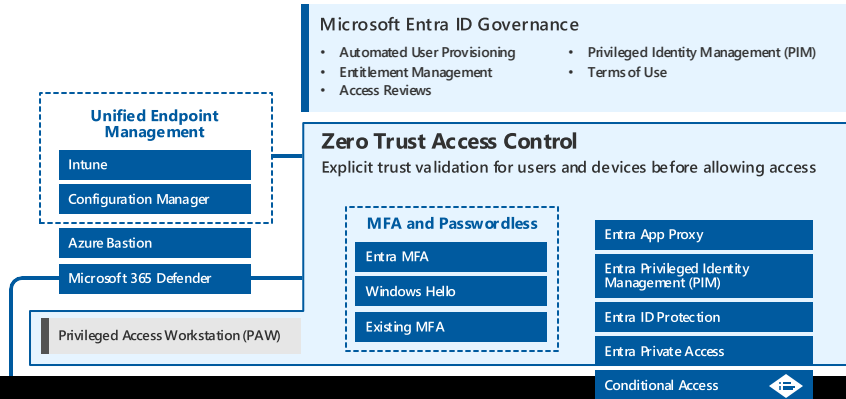
Apply Zero Trust principles Infrastructure & Platform as a Service (IaaS & PaaS) across multi-cloud cross-platform environments

Governance & Policy Enforcement

Control

Preventive Controls

Full Time Employees, Partners, and/or outsourced providers



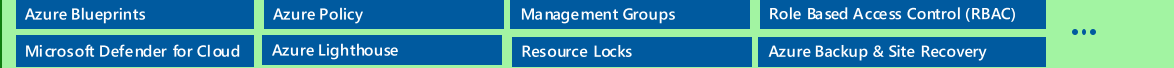
Azure Cloud Adoption Framework (CAF)

Guidance on security strategy, planning, roles and responsibilities <https://aka.ms/CAF>

Top 10 Azure Security Best Practices

Management Plane Security

Platform provided security guardrails, governance, policy, and more



Data Plane Security

Per-Application/Workload Controls

Azure Well Architected Framework (WAF)

Microsoft Cloud Security Benchmark (MCSB)

Prescriptive Best Practices and Controls

Microsoft Defender for Cloud Apps

Internal Communications (East/West)



External Communications (North/South)



Azure Firewall and Firewall Management

Defender for DevOps

Azure DevOps Security

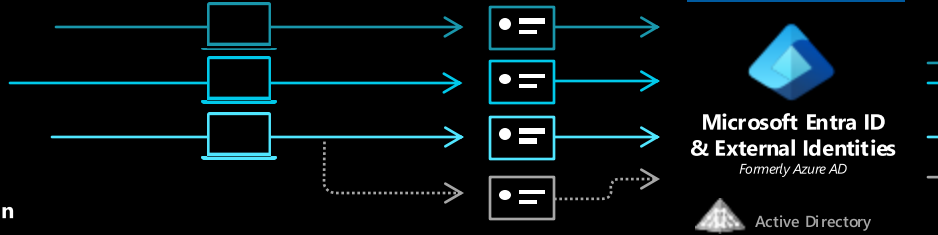
GitHub Advanced Security

Business Users

Developers

Administrators

App/Service and Automation



'Internal' Access

Workstations

Accounts

Identity

Access and Privileges

Access Applications

CI/CD Pipeline

Azure Resource Management (ARM)

Azure Portal

Command Line Interface (CLI)

Automation/API

Interfaces

Infrastructure

Resources

On-Premises & Other Cloud Resources/Data

Azure Resources/Data

External Identities

Application

API

Azure IoT Hub

Azure Sphere

Existing/Other

Internet of Things (IoT) Devices

External Identities

Customers (and 'External' Partners)

API

Azure IoT Hub

Azure Sphere

Existing/Other

Internet of Things (IoT) Devices

Network & 'External' Access

Microsoft Security Exposure Management

Microsoft Defender XDR

Unified Threat Detection and Response across IT, OT, and IoT Assets

Incident Response | Automation | Threat Hunting | Threat Intelligence

Cloud Native SIEM, SOAR, and UEBA

Microsoft Defender for Endpoint

Entra ID Protection

Microsoft Defender for Identity

Endpoint logs

Entra ID logs, access logs, alerts, risk scoring

PIM Logs

Microsoft Sentinel

Microsoft Security Copilot

Microsoft Defender for Cloud - Risk & Regulatory Compliance Reporting

Microsoft Defender External Attack Surface Management (EASM)

Azure Policy (audit) & Azure resource graph API

Microsoft Defender for Cloud Apps

MDCA Alerts

MDCA Logs

Azure activity log

Microsoft Defender for Cloud - Detections across assets and tenants

VMs & Tenants (Azure, On-prem, 3rd party clouds)

Containers and Kubernetes

IoT and Legacy OT Devices (SCADA, ICS, etc.)

Application Programming Interfaces (APIs)

And More...

Application Logs

Network Watcher - IP Flow logs, Packet Capture, Virtual TAP

Azure Service Diagnostic Logs & Metrics

Azure WAF Alerts

Azure Firewall Alerts

Azure DDoS Alerts

Security Posture

Threat Detection & Response

Visibility

Raw Logs and Signal for Investigation & Hunting

DevSecOps – Agile security for workloads

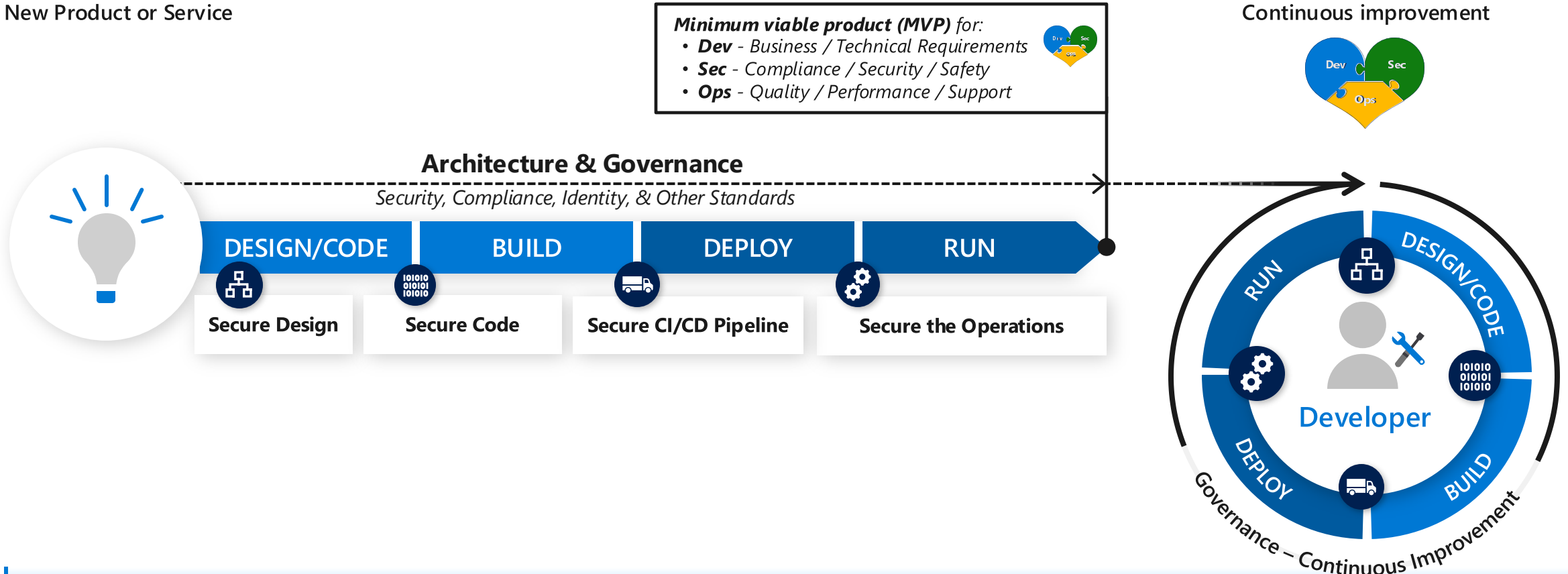
Idea Incubation

New Product or Service

First Production Release

Production DevSecOps

Continuous improvement



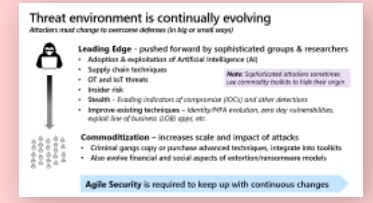
Continuous Improvement of DevSecOps Lifecycle

1. **MVP definitions** – Update minimum requirements for Dev, Sec, and Ops (agility, stability, security, identity standards, and more)
2. **Continuously improve** process, program, education, tooling, etc. to improve developer productivity, efficiency, security, identity, and more)

It's bad out there!

For sale in "bad neighborhoods" on the internet

Attacker techniques, business models, and skills/technology, are continuously evolving



Other Services

Continuous attack
supply chain innovation

Attacker for hire (per job)

\$250 per job (and up)

Ransomware Kits

\$66 upfront
(or 30% of the profit / affiliate model)

Compromised PCs / Devices

PC: \$0.13 to \$0.89
Mobile: \$0.82 to \$2.78

Spearphishing for hire

\$100 to \$1,000
(per successful account takeover)

Stolen Passwords

\$0.97 per 1,000 (average)
(Bulk: \$150 for 400M)

Denial of Service

\$766.67 per month

Attackers

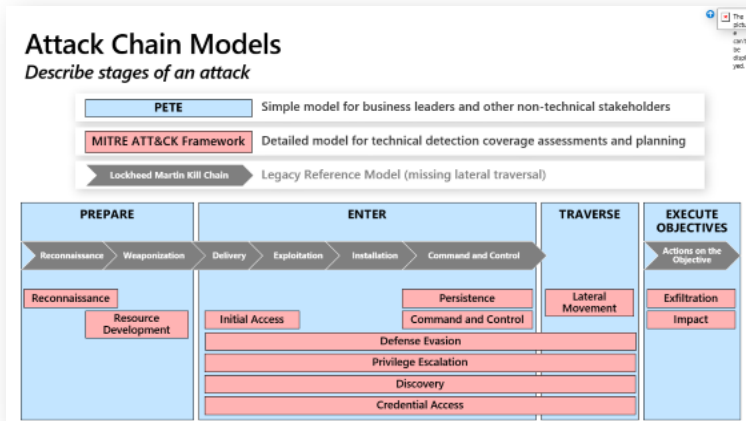
Many attack tools and
tutorials/videos available
for free on internet

Continuously Evolving Threats

Require consistency, visibility, prioritization, and continuous learning

Attack Chain Models

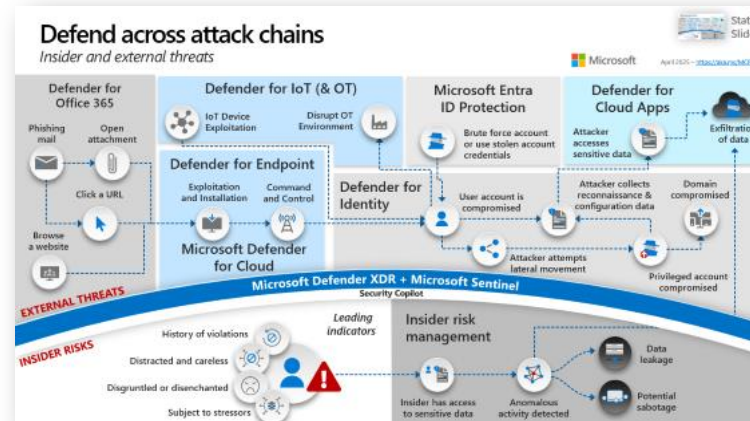
Consistently describe attacks & techniques



- Use MITRE Attack Framework to evaluate detection coverage and plan to fill visibility gaps
- Use PETE to describe incidents simply and consistently (including to business leaders)

Broad & Deep Visibility

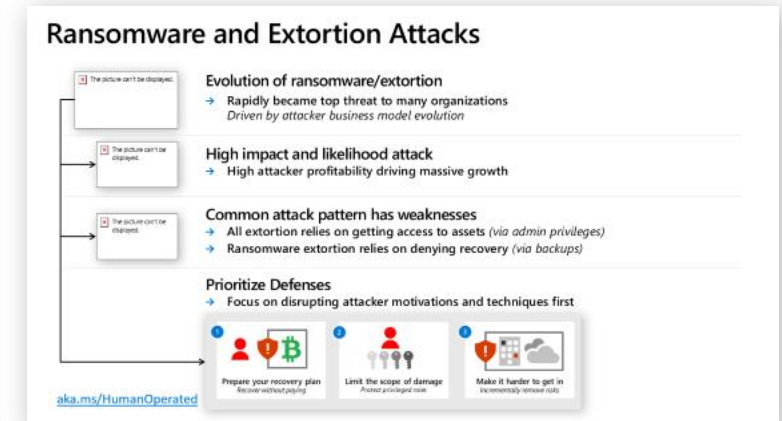
Required across assets & techniques



- Ensure you have visibility and coverage across asset types and common attack patterns

Ransomware and Extortion

Should influence defense prioritization



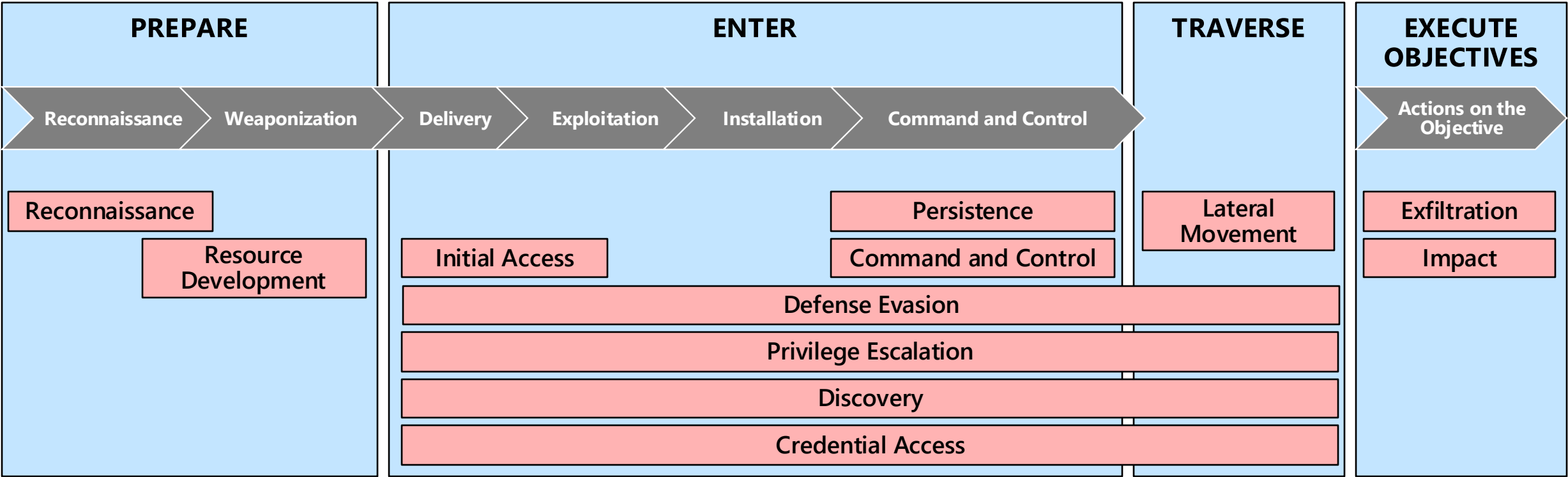
- Prioritize ransomware defenses pragmatically
<https://aka.ms/humanoperated>



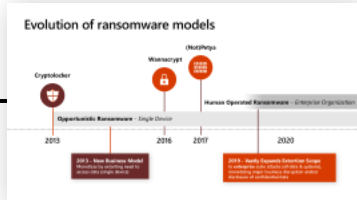
Attack Chain Models

Describe stages of an attack

PETE	Simple model for business leaders and other non-technical stakeholders
MITRE ATT&CK Framework	Detailed model for technical detection coverage assessments and planning
Lockheed Martin Kill Chain	Legacy Reference Model (missing lateral traversal)

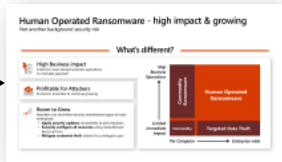


Ransomware and Extortion Attacks



Evolution of ransomware/extortion

- Rapidly became top threat to many organizations
Driven by attacker business model evolution



High impact and likelihood attack

- High attacker profitability driving massive growth

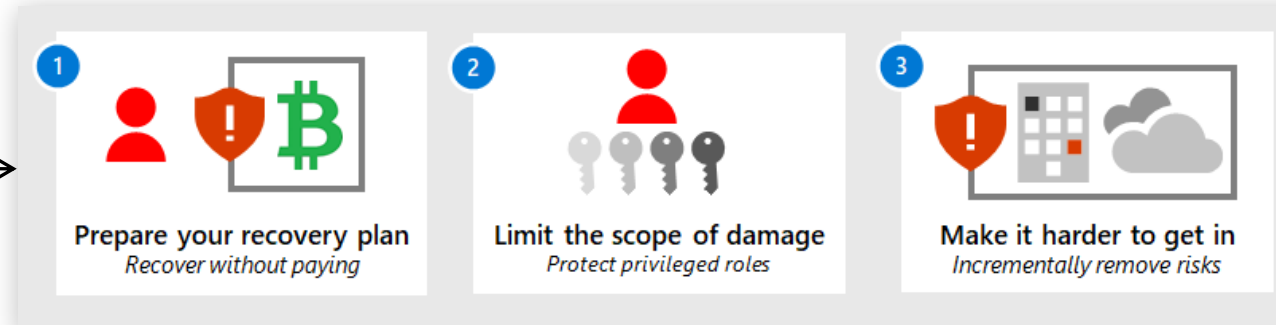


Common attack pattern has weaknesses

- All extortion relies on getting access to assets (*via admin privileges*)
- Ransomware extortion relies on denying recovery (*via backups*)

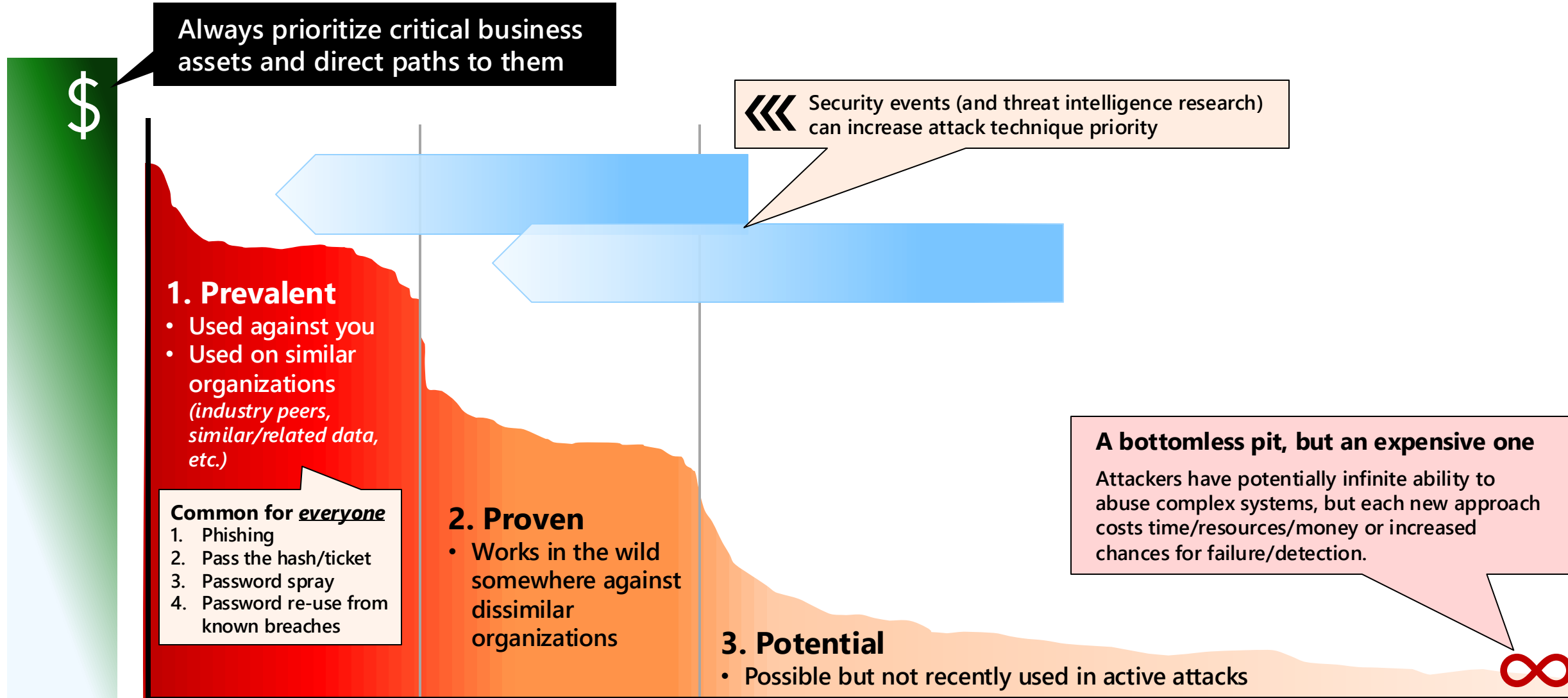
Prioritize Defenses

- Focus on disrupting attacker motivations and techniques first



Use Data to Prioritize Practically

Focus on most prevalent of effective and high impact attack techniques (not just attack of the day/week)



✓ What's in Microsoft 365 E5

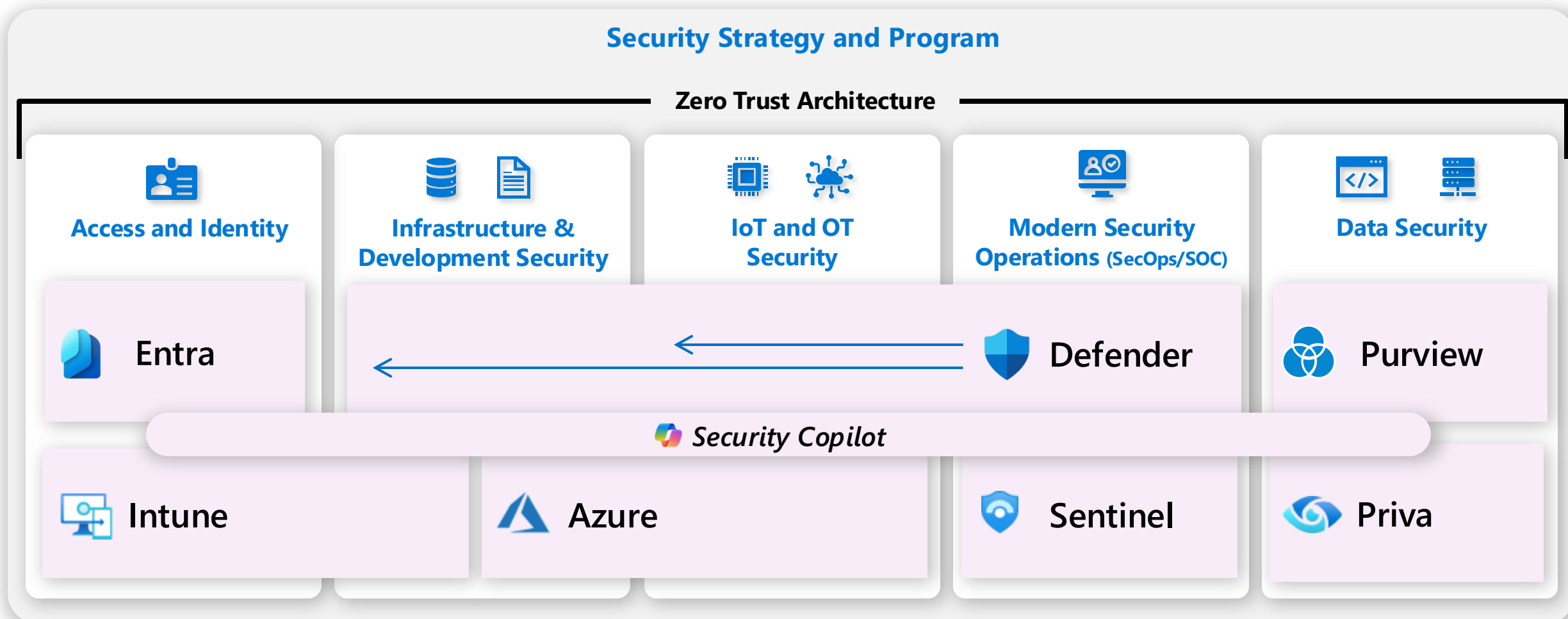


Product
Licensing
Details

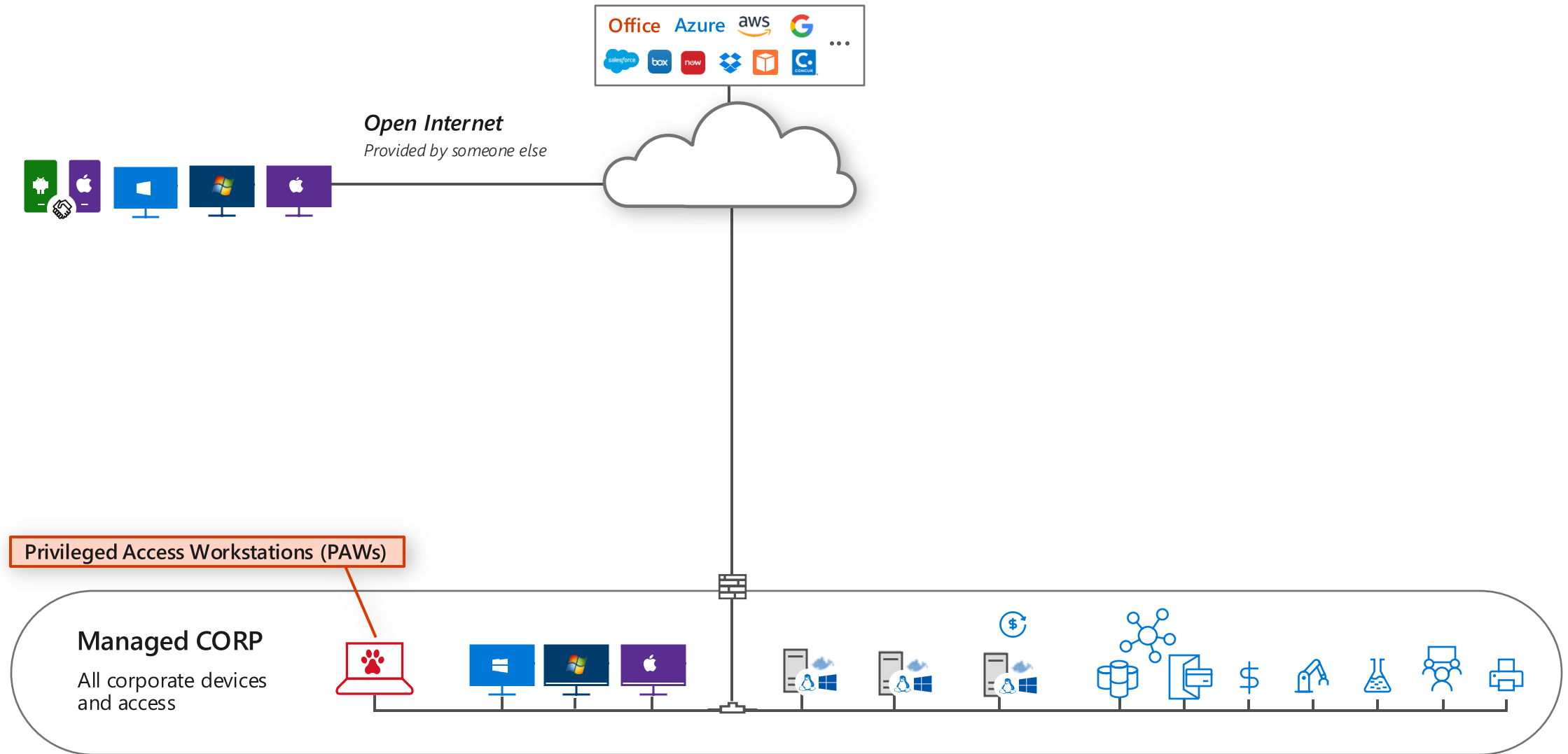
April 2025 – <https://aka.ms/MCRA>

Product Name (& Previous Product Names)	Product Category(ies)	Security Modernization Initiative(s)
Microsoft Defender for Endpoint (MDE) <i>Formerly Microsoft Defender ATP, Windows Defender ATP, Windows Defender Antivirus</i>	Extended Detection and Response (XDR) Endpoint Detection and Response (EDR) Threat and Vulnerability Management (TVM) Endpoint Protection Platforms (EPP)	• Modern Security Operations • Infrastructure and Development • Security Hygiene: Backup and Patching
Microsoft Defender for Identity (MDI) <i>Formerly Azure ATP</i>	Extended Detection and Response (XDR)	• Modern Security Operations
Microsoft Defender for Office (MDO) <i>Formerly Office 365 ATP</i>	Extended Detection and Response (XDR)	• Modern Security Operations
Microsoft Defender for Cloud Apps (MDCA) <i>Formerly Microsoft Cloud App Security</i>	Cloud App Security Broker (CASB) Extended Detection and Response (XDR)	• Access and Identity • Modern Security Operations • Data Security
Entra ID (Formerly Azure AD) • Multifactor Authentication • Microsoft Entra Conditional Access • Self-service password management • Identity Protection • Identity Governance • Privileged Identity Management (PIM)	Access Management	• Access and Identity • Modern Security Operations
Microsoft Purview • Compliance Management • Data Lifecycle Management • eDiscovery and auditing • Insider Risk Management • Information Protection		• Data Security
Windows 10 & Windows 11 • Windows Hello for Business • Windows AutoPilot • Advanced Windows Security		• Access and Identity
Microsoft Intune	Unified Endpoint Management (UEM)	• Access and Identity

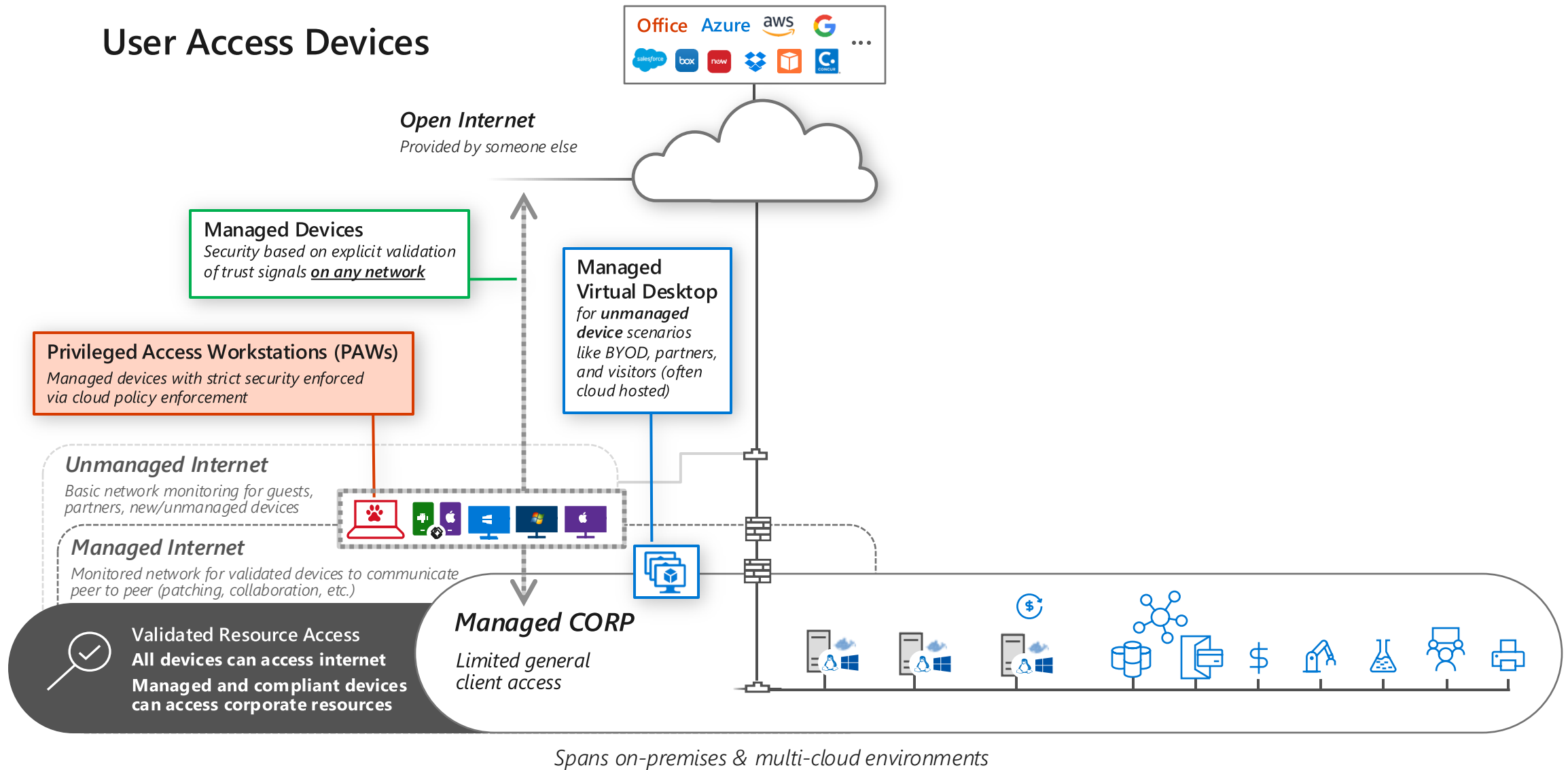
Product Families Enable Modernization Initiatives



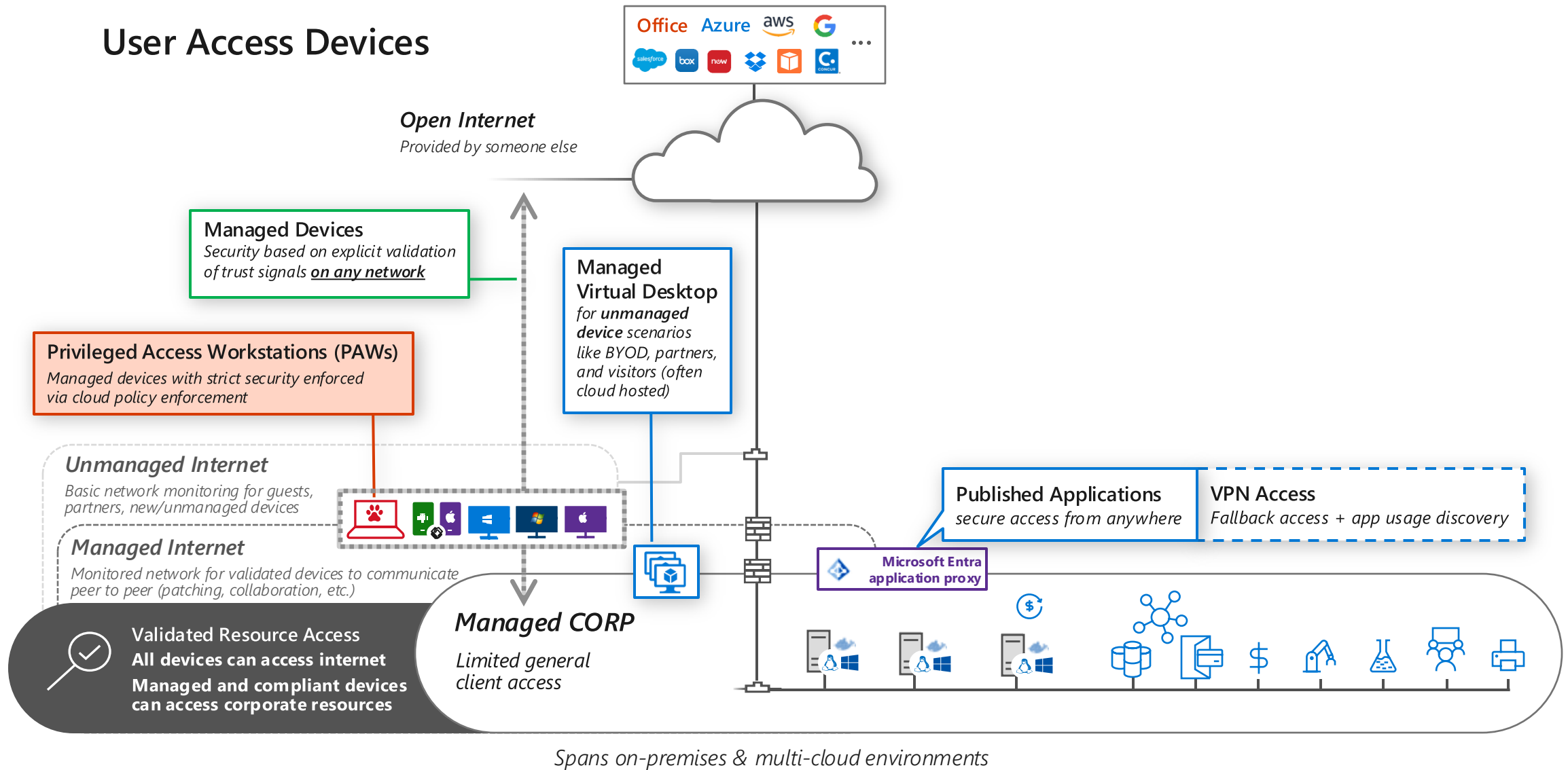
Typical 'Flat' Network



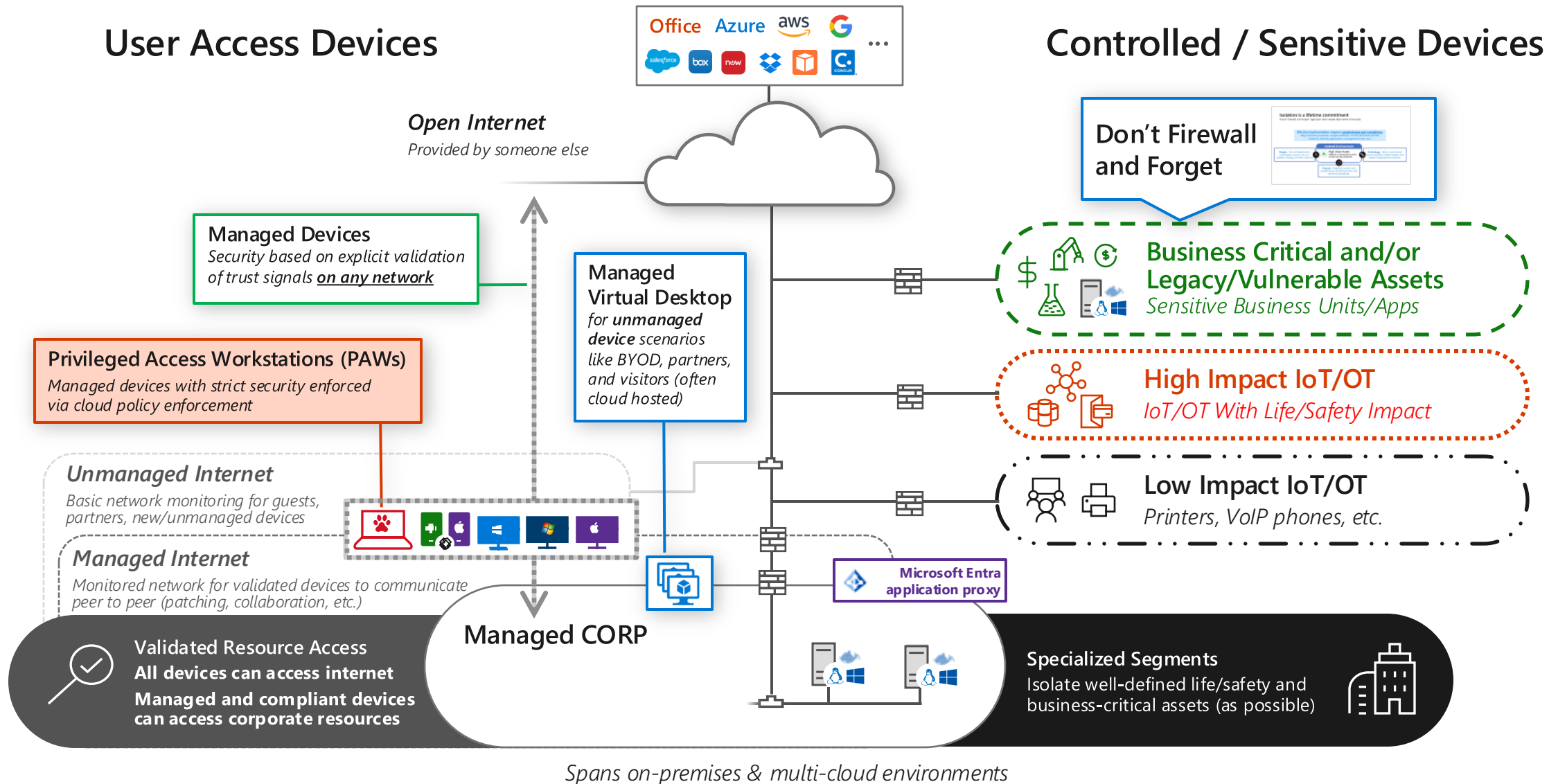
Zero Trust – Client Security Transformation



Zero Trust – App Access for Clients



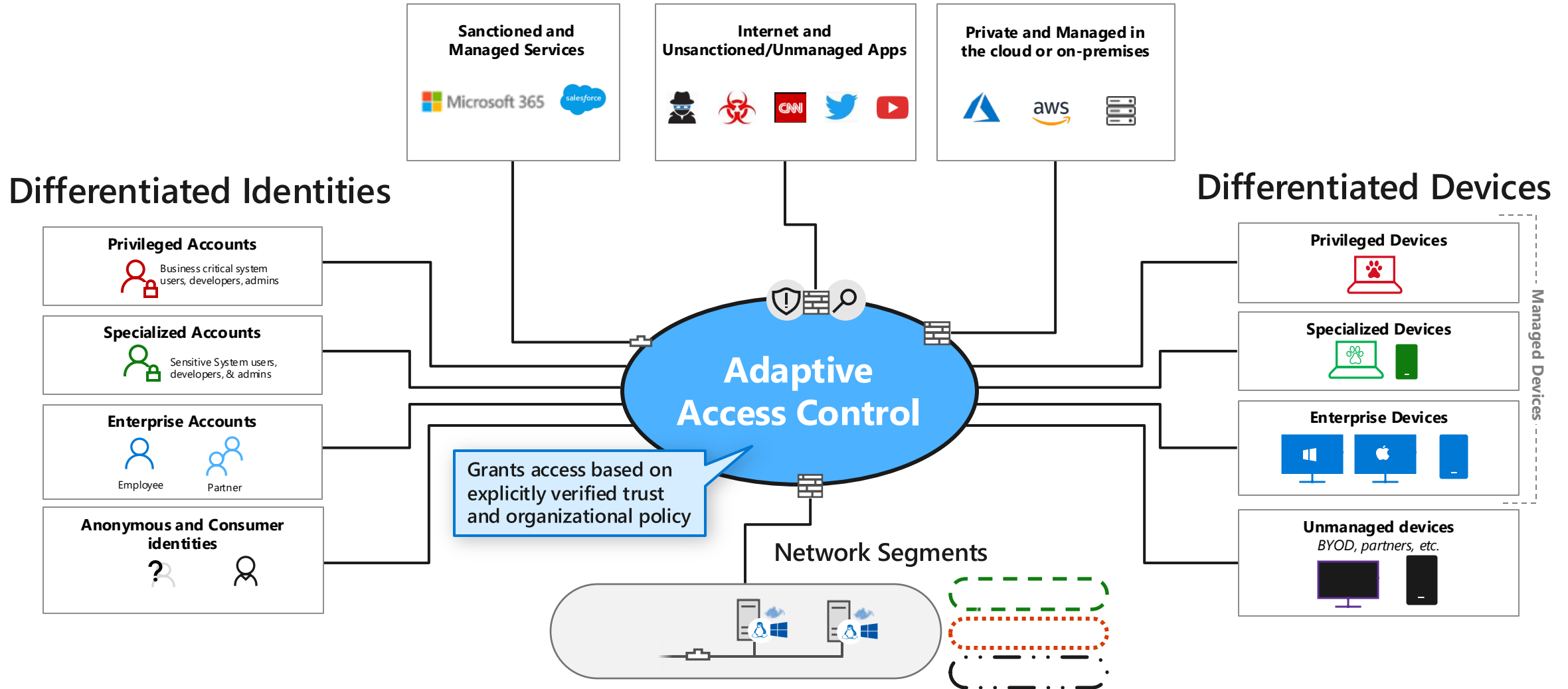
Zero Trust – Network Segment Transformation



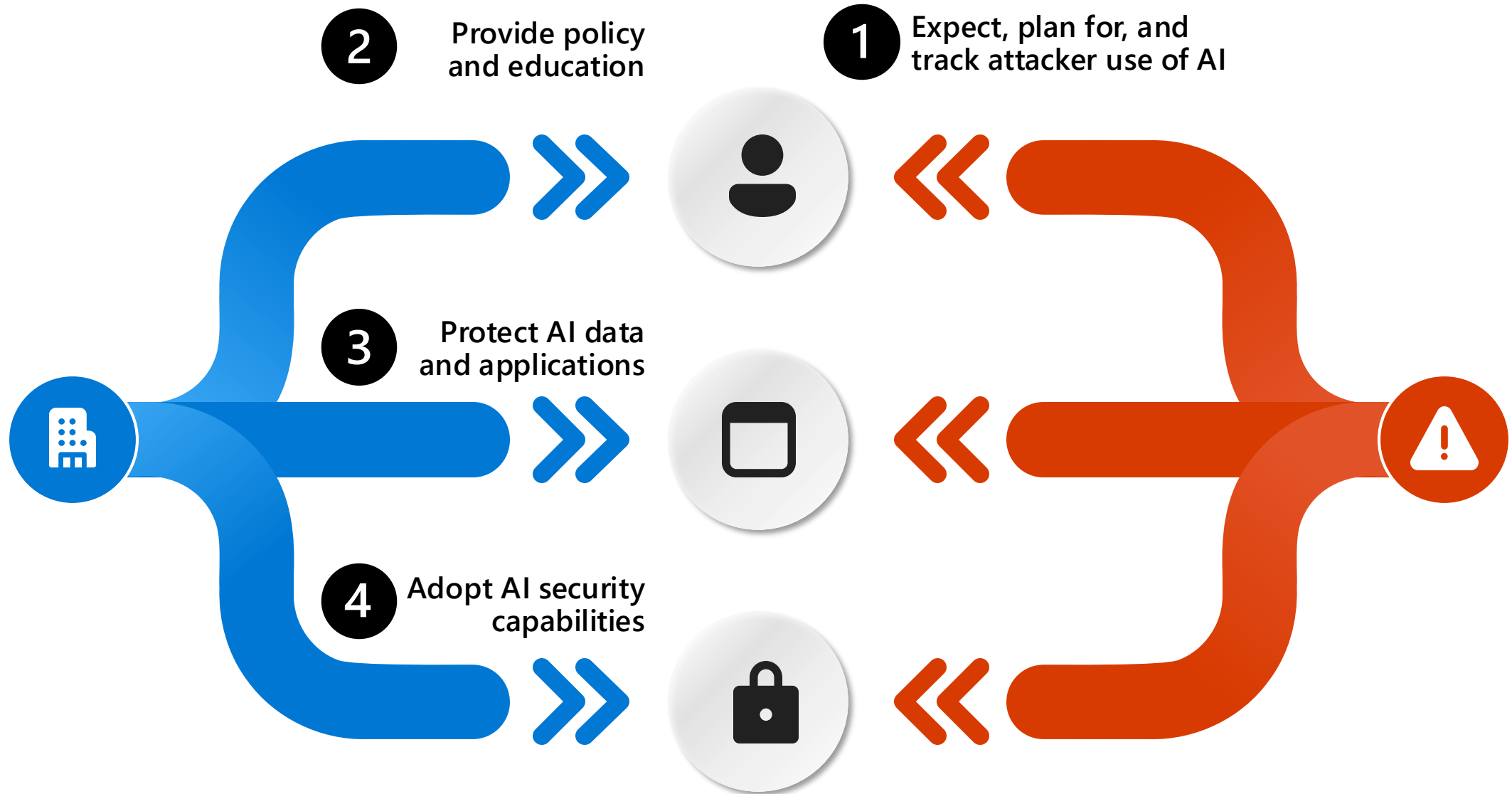
End State - Secure Access and Identity

Full Adaptive Access bridging both worlds and fulfilling Zero Trust and SASE visions

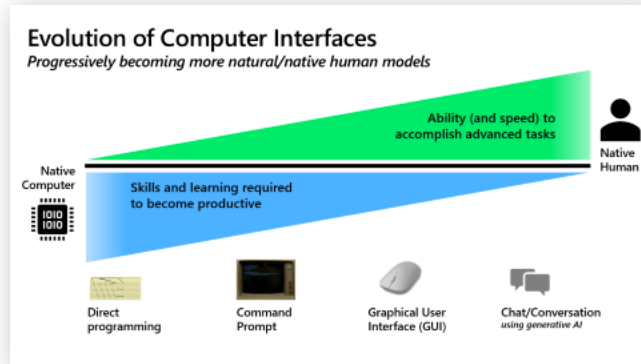
Differentiated Resources



AI creates multiple security imperatives



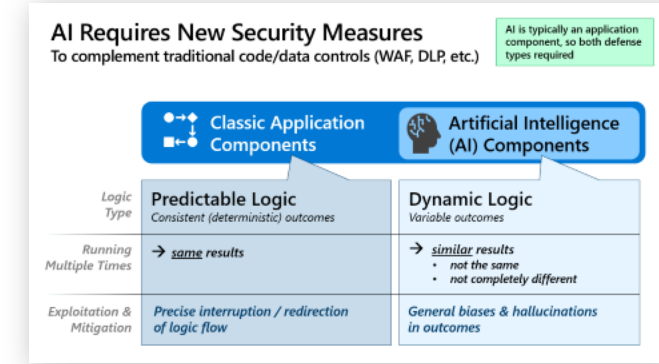
AI has multiple implications for security



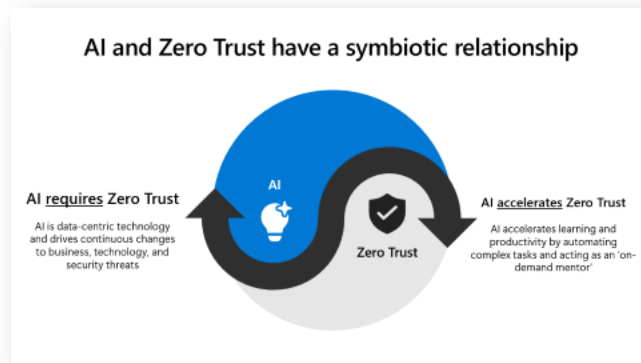
New/different interface



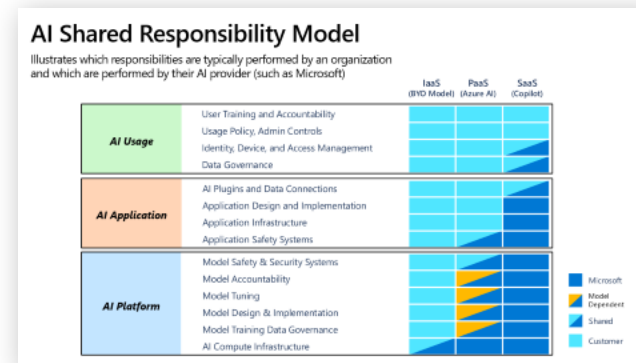
Elevates Focus on Data



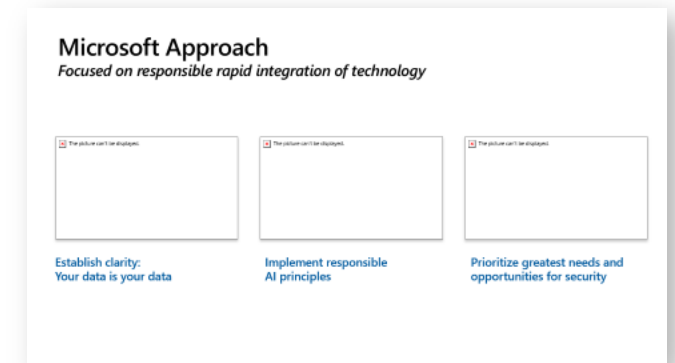
Requires new controls



AI Requires & Accelerates Zero Trust

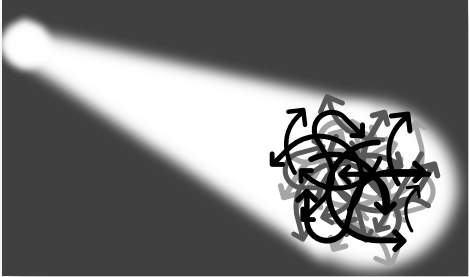


AI Shared responsibility



Microsoft Approach

AI increases data security importance *and* challenges



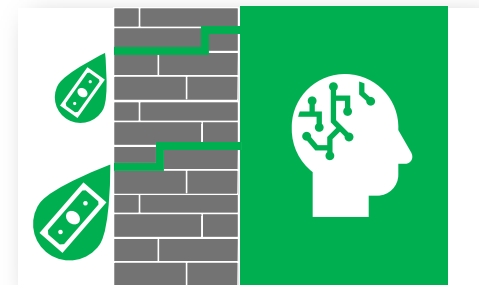
AI amplifies existing data security/governance challenges

AI makes data discovery easy, so you must fix any existing issues with data discovery, classification, & excessive permissions



AI increases value of data

AI relies on data and creates new value from it, increasing urgency to protect data from attackers trying to steal/resell it



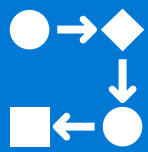
AI introduces new avenue of potential data leakage

Must secure AI applications and models to ensure their design, implementation, and use don't allow for unauthorized leakage to internal or external users

AI Requires New Security Measures

To complement traditional code/data controls (WAF, DLP, etc.)

AI is typically an application component, so both defense types required



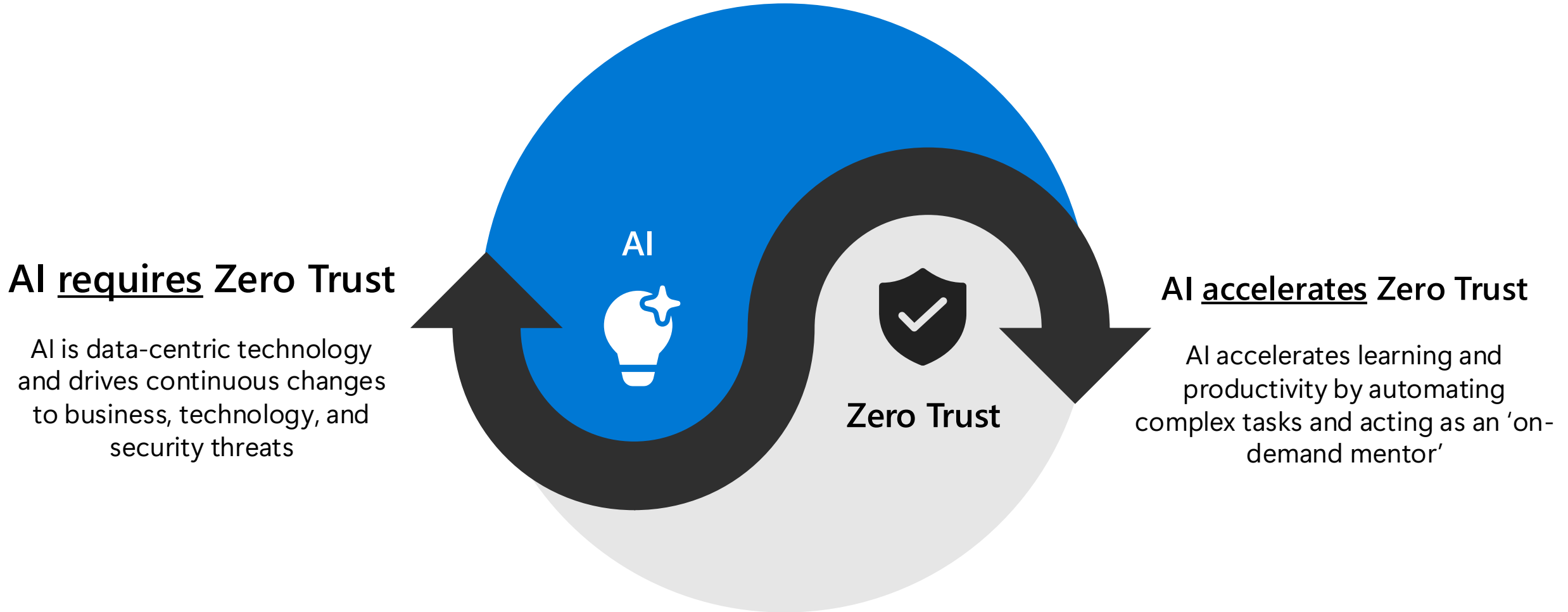
Classic Application Components



Artificial Intelligence (AI) Components

Logic Type	Predictable Logic <i>Consistent (deterministic) outcomes</i>	Dynamic Logic <i>Variable outcomes</i>
Running Multiple Times	→ <u>same</u> results	→ <u>similar</u> results • <i>not the same</i> • <i>not completely different</i>
Exploitation & Mitigation	<i>Precise interruption / redirection of logic flow</i>	<i>General biases & hallucinations in outcomes</i>

AI and Zero Trust have a symbiotic relationship



AI Shared Responsibility Model

Illustrates which responsibilities are typically performed by an organization and which are performed by their AI provider (such as Microsoft)

		IaaS (BYO Model)	PaaS (Azure AI)	SaaS (Copilot)
AI Usage	User Training and Accountability	Customer	Customer	Customer
	Usage Policy, Admin Controls	Customer	Customer	Customer
	Identity, Device, and Access Management	Customer	Customer	Customer
	Data Governance	Customer	Customer	Customer
AI Application	AI Plugins and Data Connections	Customer	Customer	Customer
	Application Design and Implementation	Customer	Customer	Microsoft
	Application Infrastructure	Customer	Customer	Microsoft
	Application Safety Systems	Customer	Customer	Microsoft
AI Platform	Model Safety & Security Systems	Customer	Shared	Microsoft
	Model Accountability	Customer	Model Dependent	Microsoft
	Model Tuning	Customer	Model Dependent	Microsoft
	Model Design & Implementation	Customer	Model Dependent	Microsoft
	Model Training Data Governance	Customer	Model Dependent	Microsoft
	AI Compute Infrastructure	Customer	Microsoft	Microsoft

Microsoft

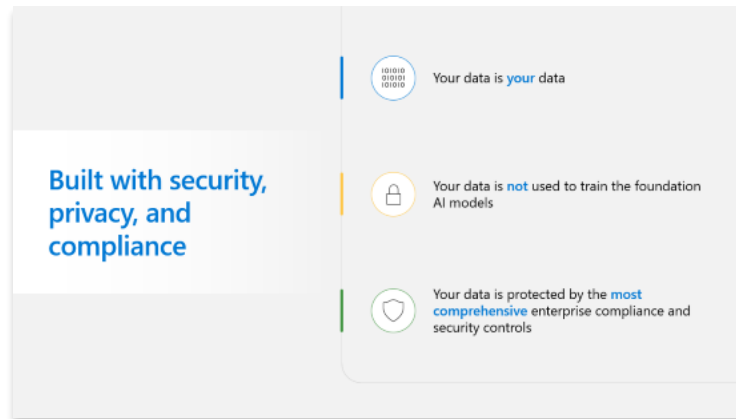
Model Dependent

Shared

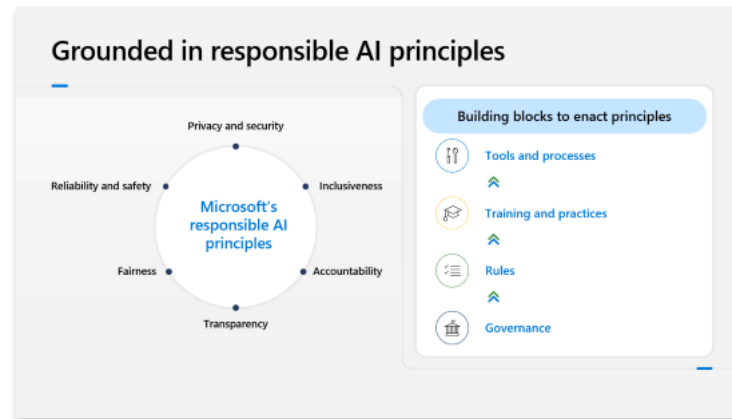
Customer

Microsoft Approach

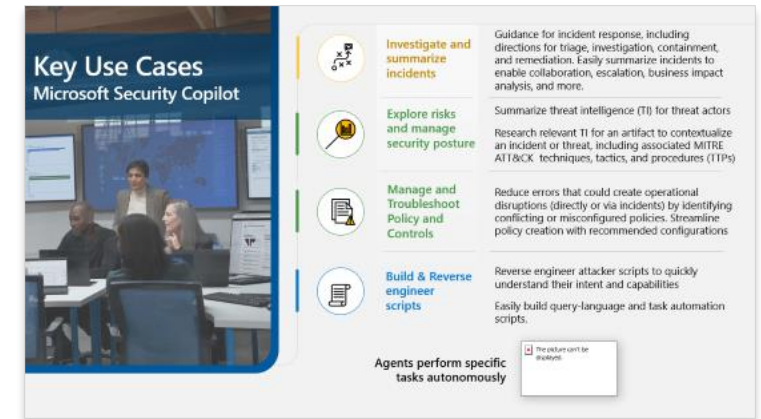
Focused on responsible rapid integration of technology



Establish clarity:
Your data is your data



Implement responsible
AI principles

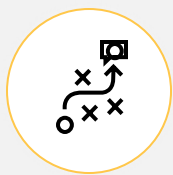


Prioritize greatest needs and
opportunities for security



Key Use Cases

Microsoft Security Copilot



Investigate and summarize incidents

Guidance for incident response, including directions for triage, investigation, containment, and remediation. Easily summarize incidents to enable collaboration, escalation, business impact analysis, and more.



Explore risks and manage security posture

Summarize threat intelligence (TI) for threat actors
Research relevant TI for an artifact to contextualize an incident or threat, including associated MITRE ATT&CK techniques, tactics, and procedures (TTPs)



Manage and Troubleshoot Policy and Controls

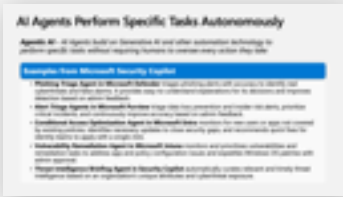
Reduce errors that could create operational disruptions (directly or via incidents) by identifying conflicting or misconfigured policies. Streamline policy creation with recommended configurations



Build & Reverse engineer scripts

Reverse engineer attacker scripts to quickly understand their intent and capabilities
Easily build query-language and task automation scripts.

Agents perform specific tasks autonomously



AI Agents Perform Specific Tasks Autonomously

Agentic AI - AI Agents build on Generative AI and other automation technology to perform specific tasks without requiring humans to oversee every action they take

Examples from Microsoft Security Copilot

- **Phishing Triage Agent in Microsoft Defender** triages phishing alerts with accuracy to identify real cyberthreats and false alarms. It provides easy-to-understand explanations for its decisions and improves detection based on admin feedback.
- **Alert Triage Agents in Microsoft Purview** triage data loss prevention and insider risk alerts, prioritize critical incidents, and continuously improve accuracy based on admin feedback.
- **Conditional Access Optimization Agent in Microsoft Entra** monitors for new users or apps not covered by existing policies, identifies necessary updates to close security gaps, and recommends quick fixes for identity teams to apply with a single click.
- **Vulnerability Remediation Agent in Microsoft Intune** monitors and prioritizes vulnerabilities and remediation tasks to address app and policy configuration issues and expedites Windows OS patches with admin approval.
- **Threat Intelligence Briefing Agent in Security Copilot** automatically curates relevant and timely threat intelligence based on an organization's unique attributes and cyberthreat exposure.

Review – Artificial Intelligence (AI)

- GenAI enables a new interface (natural language)
 - *Makes technology easier to use and learn*
 - *Enables people to do more advanced tasks*
- Critical to adapt quickly to this technology
 - *Educate on and mitigate attacker use of AI*
 - *Embrace security use of AI*
 - *Protect business use of AI*
- Securing AI is a shared responsibility
- Microsoft Approach to AI
 - *Establish clarity: your data is your data*
 - *Implement responsible AI principles*
 - *Focus initial security priorities on greatest needs*



Resources and References

